# Siber Güvenlik Mühendisliği Eğitimi - 2026

## 101 BİTİRME PROJESİ: "The Analyst & The Hunter"

**Mert ACAR**

**11.03.2026**

# FAZ 1: "Siber Triatlon" Operasyon Raporu

## Bölüm A: Teori ve Mimari (Research & Logic)

**1. İşletim Sistemi ve Şifreleme: "Anahtarlar Kimde?"**

**SSH Private Key (Gizli Anahtar):**

• Parola insanların aklında kalabilecek şekilde nispeten kısa şekildedir. Bot ağları, saniyede sayısız parola ile sunucuya yetkisiz erişim sağlayabilir. Bu yüzden SSH anahtarları kullanılır. SSH anahtarları çok uzun şekilde oluşan matematiksel değerlerdir.

• SSH anahtarları, **Asimetrik Şifreleme** adı verilen bir mekanizma ile çalışır. Bu sistemde anahtarlar tekil değil, matematiksel olarak birbirine sıkı sıkıya bağlı bir **çift** halinde üretilir:

**Public Key (Açık Anahtar):** Birinin bu anahtarı ele geçirmesi hiçbir güvenlik zafiyeti yaratmaz; çünkü Public Key sadece veriyi şifreleyebilir **.**

**Private Key (Gizli Anahtar):** Sadece senin bilgisayarında, güvenli bir dizinde saklanır. Asla kimseyle paylaşılmaz. Public Key ile kilitlenen bir şeyi sadece bu Private Key açabilir.

**Hex Dump:**

• Bilgisayarlar 1 ve 0 ‘lardan oluşan binary sistemi kullanılırlar. Bilgisayarlar her şeyi böyle kaydeder. Bir .txt dosyasını Not defteri’nde okuyabiliriz çünkü basit metinlerden oluşuyor ama bir fotoğrafı (.jpg), bir şarkıyı (.mp3) veya çalıştırılabilir bir programı (.exe) Not Defteri ile açmaya çalışırsan ekranda anlamsız, garip semboller (Örneğin: %&*) görürsün. Burada Hex Dump araçlarına ihtiyaç duyarız.

•Hex Dump, ekrana milyonlarca 0 ve 1 yazdırmak yerine, ikişerli karakterler halinde (41 42 43 00 FF gibi) bu onaltılık kodları yazdırır. Bu, dosyayı okumayı ve analiz etmeyi çok daha kolay hale getirir.

**2. Web Mimarisi: "Sunucu Tarafı (Server-Side)"**

**Client-Side vs Server-Side:**

• PHP, Python, Node.js veya Java gibi diller **sunucu tarafında** çalışır. Tarayıcıda bir web adresini yazıp “ENTER” bastıktan sonra sunucuya bir istek (http request ) gider. Sunucu bu isteği , arka planda o sayfaya ait PHP veya Python kodlarını çalıştırır. Bu kodlar veritabanına bağlanır, kullanıcı bilgilerini kontrol eder, matematiksel hesaplamalar yapar. Sunucu bu işlemlerden sonra bize HTML,CSS VE JavaScript ‘ten oluşan bir sonuç gönderir. Biz "Sağ Tık > Kaynağı İncele" dediğimizde, tarayıcının sunucudan teslim aldığı nihai çıktıyı görürüz. PHP, Python kodlarını göremeyiz.

•Kötü niyetli bir kişi bu kodları görebilseydi, veritabanı şifresini okuyup tüm kullanıcı verilerini çalabilir veya sistemin açıklarını anında bulabilirdi. Bu yüzden sunucu, uygulamanın beynini (kodun kendisini) asla dışarı çıkarmaz, sadece beynin ürettiği raporu (HTML) dışarı verir.

**Command Injection (Komut Enjeksiyonu):**

• Bazen web siteleri, kendi içlerindeki kodlarla (PHP, Python, Node.js vb.) yapamayacakları işler için doğrudan altında çalıştıkları işletim sisteminden (Linux veya Windows) yardım isterler. İşte zafiyet tam bu noktada, geliştirici senin arama kutusuna yazdığın metni alıp **hiçbir süzgeçten geçirmeden** doğrudan Linux terminaline (Shell) yapıştırdığında başlar.

•Linux (ve Windows) terminalinin çok güçlü bir özelliği vardır: Aynı satırda birden fazla komutu peş peşe çalıştırabilirsin. Bunun için araya bazı özel karakterler (metakarakterler) koyman yeterlidir.

•Web sitesi güvenlik kontrolü yapmadan ( **8.8.8.8 ; ls -la**) komutu linux'a gönderir. Linux terminalinde çalıştırılan komut şuna dönüşür: **ping -c 4 8.8.8.8 ; ls -la** . Web sitesi, Linux'tan dönen **tüm metni** alıp sana ekranda gösterdiği için, bir bakmışsın ki ekranda sadece ping sonuçları değil, o sunucudaki uygulamanın bulunduğu klasörün içindeki tüm dosyalar (index.html, config.js, database.sqlite vb.) listelenmiş!

**3. Ağ Anatomisi: "Avın İzleri"**

**C2 (Command and Control) Nedir?**

• Zararlı yazılımlar genellikle bilgisayara girdikten sonra antivirüs programlarına yakalamamak içini kendini kamufle eder.  Sonrasında C2 sunucusuna bağlanıp ne yapması gerektiğini öğrenir. Kendi başına öğrendiği edindiği bilgilerin C2 sunucusuna hiçbir faydası olmaz , bağlanıp edindiği bilgileri sessizce paketleyip C2 sunucusuna yollar.

•C2 sunucusuna belli aralıklarla ben buradayım hala diye sinyal yollar.

**PCAP Analizi:**

Antivirüs logları bir analiste yalnızca "sistemde şüpheli bir dosya veya işlem olduğunu" söyler. PCAP analizi ise o şüpheli işlemin "sisteme nasıl girdiğini, kimden emir aldığını ve tam olarak ne çaldığını" dijital kanıtlarla gösteren en temel gerçektir.

# Bölüm B: Saha Operasyonu (Boss Fights)

## Cephe 1: İşletim Sistemleri Ustası (Linux / Bash)

```
PS C:\Users\LENOVO> ssh bandit11@bandit.labs.overthewire.org -p 2220
                      _                     _ _ _
                     | |__   __ _ _ __   __| (_) |_
                     | '_ \ / _` | '_ \ / _` | | __|
                     | |_) | (_| | | | | (_| | | |_
                     |_.__/ \__,_|_| |_|\__,_|_|\__|


                    This is an OverTheWire game server.
            More information on http://www.overthewire.org/wargames

backend: gibson-1
bandit11@bandit.labs.overthewire.org's password:

      ,----..            ,----,          .---.
     /   /   \        ,/   .`|         /. ./|
    /   .     :      ,`    .'  :     .--'.  ' ;
   .   /   ;.  \   ;    ;     /    /__./ \ : |
  .   ;   /  ` ;  .'___,/    ,' .--'.  '   \' .
  ;   |  ; \ ; | |    :     | /___/ \ |    ' '
  |   :  | ; | ' ;    |.';  ; ;   \  \;      :
  .   |  ' ' ' : `____'  |  | \   ;  `      |
  '   ;  \; /  |     '   :  ;   .   \    .\  ;
   \   \  ',  /      |   |  '    \   \   ' \ |
    ;   :    /       '   :  |     :   '  |--"
     \   \ .'        ;   |.'       \   \ ;
  www. `---` ver     '---' he       '---" ire.org


Welcome to OverTheWire!
```

```
Welcome to OverTheWire!

If you find any problems, please report them to the #wargames channel on
discord or IRC.

--[ Playing the games ]--

  This machine might hold several wargames.
  If you are playing "somegame", then:

    * USERNAMES are somegame0, somegame1, ...
    * Most LEVELS are stored in /somegame/.
    * PASSWORDS for each level are stored in /etc/somegame_pass/.

  Write-access to homedirectories is disabled. It is advised to create a
  working directory with a hard-to-guess name in /tmp/.  You can use the
  command "mktemp -d" in order to generate a random and hard to guess
  directory in /tmp/.  Read-access to both /tmp/ is disabled and to /proc
  restricted so that users cannot snoop on eachother. Files and directories
  with easily guessable or short names will be periodically deleted! The /tmp
  directory is regularly wiped.
  Please play nice:

    * don't leave orphan processes running
    * don't leave exploit-files laying around
    * don't annoy other players
    * don't post passwords or spoilers
    * again, DONT POST SPOILERS!
```

```
      This includes writeups of your solution on your blog or website!

--[ Tips ]--

  This machine has a 64bit processor and many security-features enabled
  by default, although ASLR has been switched off.  The following
  compiler flags might be interesting:

    -m32                    compile for 32bit
    -fno-stack-protector    disable ProPolice
    -Wl,-z,norelro          disable relro

  In addition, the execstack tool can be used to flag the stack as
  executable on ELF binaries.

  Finally, network-access is limited for most levels by a local
  firewall.

--[ Tools ]--

 For your convenience we have installed a few useful tools which you can find
 in the following locations:

    * gef (https://github.com/hugsy/gef) in /opt/gef/
    * pwndbg (https://github.com/pwndbg/pwndbg) in /opt/pwndbg/
    * gdbinit (https://github.com/gdbinit/Gdbinit) in /opt/gdbinit/
    * pwntools (https://github.com/Gallopsled/pwntools)
    * radare2 (http://www.radare.org/)

--[ More information ]--
```

```
--[ More information ]--

  For more information regarding individual wargames, visit
  http://www.overthewire.org/wargames/

  For support, questions or comments, contact us on discord or IRC.

  Enjoy your stay!

bandit11@bandit:~$ ls
data.txt
bandit11@bandit:~$ cat data.txt
Gur cnffjbeq vf 7k16JArUVv5LxVuJfsSVdbbtaHGlw9D4
bandit11@bandit:~$ cat data.txt | tr 'a-zA-Z' 'n-za-mN-ZA-M'
The password is 7x16WNeHIi5YkIhWsfFIqoognUTyj9Q4
bandit11@bandit:~$ exit
logout
Connection to bandit.labs.overthewire.org closed.
PS C:\Users\LENOVO>
```

- **cat data.txt**: Dosyanın içindeki o anlamsız, şifreli metni okumak için kullandık.

- **(Boru / Pipe):** Okunan veriyi doğrudan ekrana basmak yerine, havada yakalayıp bir sonraki komuta "girdi" olarak yönlendirmek için kullandık.

- **tr 'a-zA-Z' 'n-za-mN-ZA-M':** tr (translate) çevirmen komutudur. Gelen metindeki tüm harfleri bulup, ROT13 kuralına göre 13 karakter geri/ileri kaydırarak metni orijinal haline döndürmesini sağladık.

```
PS C:\Users\LENOVO> ssh bandit12@bandit.labs.overthewire.org -p 2220
                      _                     _ _ _
                     | |__   __ _ _ __   __| (_) |_
                     | '_ \ / _` | '_ \ / _` | | __|
                     | |_) | (_| | | | | (_| | | |_
                     |_.__/ \__,_|_| |_|\__,_|_|\__|


                    This is an OverTheWire game server.
            More information on http://www.overthewire.org/wargames

backend: gibson-1
bandit12@bandit.labs.overthewire.org's password:

      ____..             ____,           .___.
     ,   /  \         ,/   .`|         /. ./|
    /   .     :      ,    .'  :     .__'.   ' :
   .   /   ;.  \   ;    ;     /    /__./ \ : |
  .   ;   /  ` . .'___,/     ' .__'.   '   \' .
  ;   |  . \ ; | |    :     | /___/ \ |    ' '
  |   :  | ; | ' ;    |.';  ; ;   \  \;      :
  .   |  ' ' ' : `____'  |  | \   ;  `      |
  '   ;  \; /  |     '   :  ;   .   \    .\  ;
   \   \  ',  /      |   |  '    \   \   ' \ |
    ;   :    /       '   :  |     :   '  |--"
     \   \ .'        ;   |.'       \   \ ;
  www. `---` ver     '___' he       '___" ire.org
```

```
bandit12@bandit:~$ mkdir /tmp/benim_odam
bandit12@bandit:~$ cp data.txt /tmp/benim_odam/
bandit12@bandit:~$ cd /tmp/benim_odam/
bandit12@bandit:/tmp/benim_odam$ xxd -r data.txt > veri1
bandit12@bandit:/tmp/benim_odam$ file veri1
veri1: gzip compressed data, was "data2.bin", last modified: Tue Oct 14 09:26:06 2025, max compression, from Unix, or
iginal size modulo 2^32 564
bandit12@bandit:/tmp/benim_odam$ mv veri1 veri1.gz
bandit12@bandit:/tmp/benim_odam$ gzip -d veri1.gz
bandit12@bandit:/tmp/benim_odam$ file veri1
veri1: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/benim_odam$ mv veri1 veri1.bz2
bandit12@bandit:/tmp/benim_odam$ bzip2 -d veri1.bz2
bandit12@bandit:/tmp/benim_odam$ file veri1
veri1: gzip compressed data, was "data4.bin", last modified: Tue Oct 14 09:26:06 2025, max compression, from Unix, or
iginal size modulo 2^32 20480
bandit12@bandit:/tmp/benim_odam$ mv veri1 veri1.tar
bandit12@bandit:/tmp/benim_odam$ tar -xf veri1.tar
bandit12@bandit:/tmp/benim_odam$ ls
data5.bin  data.txt  veri1.tar
bandit12@bandit:/tmp/benim_odam$ file data5.bin
data5.bin: POSIX tar archive (GNU)
bandit12@bandit:/tmp/benim_odam$ mv data5.bin data5.tar
bandit12@bandit:/tmp/benim_odam$ tar -xf data5.tar
bandit12@bandit:/tmp/benim_odam$ ls
data5.tar  data6.bin  data.txt  veri1.tar
bandit12@bandit:/tmp/benim_odam$ file data6.bin
data6.bin: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/benim_odam$ mv data6.bin data6.bz2
```

```
data5.tar  data6.bin  data.txt  veri1.tar
bandit12@bandit:/tmp/benim_odam$ file data6.bin
data6.bin: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/benim_odam$ mv data6.bin data6.bz2
bandit12@bandit:/tmp/benim_odam$ bzip2 -d data6.bz2
bandit12@bandit:/tmp/benim_odam$ ls
data5.tar  data6  data.txt  veri1.tar
bandit12@bandit:/tmp/benim_odam$ file data6
data6: POSIX tar archive (GNU)
bandit12@bandit:/tmp/benim_odam$ mv data6 data6.tar
bandit12@bandit:/tmp/benim_odam$ tar -xf data6.tar
bandit12@bandit:/tmp/benim_odam$ ls
data5.tar  data6.tar  data8.bin  data.txt  veri1.tar
bandit12@bandit:/tmp/benim_odam$ file data8.bin
data8.bin: gzip compressed data, was "data9.bin", last modified: Tue Oct 14 09:26:06 2025, max compression, from Unix
, original size modulo 2^32 49
bandit12@bandit:/tmp/benim_odam$ mv data8.bin data8.gz
bandit12@bandit:/tmp/benim_odam$ gzip -d data8.gz
bandit12@bandit:/tmp/benim_odam$ ls
data5.tar  data6.tar  data8  data.txt  veri1.tar
bandit12@bandit:/tmp/benim_odam$ file data8
data8: ASCII text
bandit12@bandit:/tmp/benim_odam$ cat data8
The password is FO5dwFsc0cbaIiH0h8J2eUks2vdTDwAn
bandit12@bandit:/tmp/benim_odam$ exit
logout
Connection to bandit.labs.overthewire.org closed.
PS C:\Users\LENOVO>
```

- **mkdir /tmp/benim_odam & cp ...:** Ana dizinde dosya oluşturma yetkimiz olmadığı için /tmp klasöründe kendi çalışma alanımızı yaratıp dosyayı oraya kopyaladık.

- **xxd -r data.txt > veri1**: xxd komutunu -r (reverse) parametresiyle kullanarak, metin halindeki Hex Dump'ı tekrar orijinal (binary) bilgisayar dosyasına dönüştürdük.

- **file [dosya_adi]:** Linux sistemleri dosya uzantılarına (.zip, .rar vb.) güvenmez. Bu komutla dosyanın *gerçekte* ne tür bir sıkıştırma algoritması kullandığını (röntgenini çekerek) öğrendik.

- **mv [eski_ad] [yeni_ad.uzantı]:** Dosyaya, file komutunun bize söylediği sonuca uygun doğru uzantıyı verdik.

- **gzip -d, bzip2 -d, tar -xf**: Doğru uzantıyı verdiğimiz sıkıştırılmış paketleri dışarı çıkartmak (patlatmak) için kullandığımız arşiv açma komutlarıdır.

```
C:\Users\LENOVO>ssh bandit13@bandit.labs.overthewire.org -p 2220
                         _                     _ _ _
                        | |__   __ _ _ __   __| (_) |_
                        | '_ \ / _` | '_ \ / _` | | __|
                        | |_) | (_| | | | | (_| | | |_
                        |_.__/ \__,_|_| |_|\__,_|_|\__|


                      This is an OverTheWire game server.
            More information on http://www.overthewire.org/wargames

backend: gibson-1
bandit13@bandit.labs.overthewire.org's password:

      .----..            ____          .---.
     /   /  \         ,/   .`|        /. ./|
    /   .    :      ,`    .'  :     .__'.  ' ;
   .   /   ;.  \   ;    ;     /    /__./ \ : |
  .   ;   /  ` ; .'___,/    ,' .__'.   '   \' .
  ;   |  ; \ ; | |    :     | /___/ \ |    ' '
  |   :  | ; | ' ;    |.';  ; ;   \  \;      :
  .   |  ' ' ' : `____'  |  | \   ;  `      |
  '   ;  \; /  |     '   :  ;   .   \    .\  ;
   \   \  ',  /      |   |  '    \   \   ' \ |
    ;   :    /       '   :  |     :   '  |--"
     \   \ .'        ;   |.'       \   \ ;
  www. `---` ver     '---' he       '---" ire.org
```

```
bandit13@bandit:~$ ls
HINT  sshkey.private
bandit13@bandit:~$ ssh -i sshkey.private bandit14@localhost -p 2220
The authenticity of host '[localhost]:2220 ([127.0.0.1]:2220)' can't be established.
ED25519 key fingerprint is SHA256:C2ihUBV7ihnV1wUXRb4RrEcLfXC5CXlhmAAM/urerLY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Could not create directory '/home/bandit13/.ssh' (Permission denied).
Failed to add the host to the list of known hosts (/home/bandit13/.ssh/known_hosts).
                         _                     _ _ _
                        | |__   __ _ _ __   __| (_) |_
                        | '_ \ / _` | '_ \ / _` | | __|
                        | |_) | (_| | | | | (_| | | |_
                        |_.__/ \__,_|_| |_|\__,_|_|\__|


                      This is an OverTheWire game server.
```

```
!!! You are trying to log into this SSH server with a password on port 2220 from localhost.
!!! Connecting from localhost is blocked to conserve resources.
!!! Please log out and log in again.

backend: gibson-1
Received disconnect from 127.0.0.1 port 2220:2: no authentication methods enabled
Disconnected from 127.0.0.1 port 2220
```

```
bandit13@bandit:~$ cat sshkey.private
-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAxkkOE83W2cOT7IWhFc9aPaaQmQDdgzuXCv+ppZHa++buSkN+
gg0tcr7Fw8NLGa5+Uzec2rEg0WmeevB13AIoYp0MZyETq46t+jk9puNwZwIt9XgB
ZufGtZEwWbFWw/vVLNwOXBe4UWStGRWzgPpEeSv5Tb1VjLZIBdGphTIK22Amz6Zb
ThMsiMnyJafEwJ/T8PQO3myS91vUHEuoOMAzoUID4kN0MEZ3+XahyK0HJVq68KsV
ObefXG1vvA3GAJ29kxJaqvRfgYnqZryWN7w3CHjNU4c/2Jkp+n8L0SnxaNA+WYA7
jiPyTF0is8uzMlYQ4l1Lzh/8/MpvhCQF8r22dwIDAQABAoIBAQC6dWBjhyEOzjeA
J3j/RWmap9M5zfJ/wb2bfidNpwbB8rsJ4sZIDZQ7XuIh4LfygoAQSS+bBw3RXvzE
pvJt3SmU8hIDuLsCjL1VnBY5pY7Bju8g8aR/3FyjyNAqx/TLfzlLYfOu7i9Jet67
xAh0tONG/u8FB5I3LAI2Vp6OviwvdWeC4nOxCthldpuPKNLA8rmMMVRTKQ+7T2VS
nXmwYckKUcUgzoVSpiNZaS0zUDypdpy2+tRH3MQa5kqN1YKjvF8RC47woOYCktsD
o3FFpGNFec9Taa3Msy+DfQQhHKZFKIL3bJDONtmrVvtYK40/yeU4aZ/HA2DQzwhe
ol1AfiEhAoGBAOnVjosBkm7sblK+n4IEwPxs8sOmhPnTDUy5WGrpSCrXOmsVIBUf
laL3ZGLx3xCIwtCnEucB9DvN2HZkupc/h6hTKUYLqXuyLD8njTrbRhLgbC9QrKrS
M1F2fSTxVqPtZDlDMwjNR04xHA/fKh8bXXyTMqOHNJTHHNhbh3McdURjAoGBANkU
1hqfnw7+aXncJ9bjysr1ZWbqOE5Nd8AFgfwaKuGTTVX2NsUQnCMWdOp+wFak40JH
PKWkJNdBG+ex0H9JNQsTK3X5PBMAS8AfX0GrKeuwKWA6erytVTqjOfLYcdp5+z9s
8DtVCxDuVsM+i4X8UqIGOlvGbtKEVokHPFXP1q/dAoGAcHg5YX7WEehCgCYTzpO+
xysX8ScM2qS6xuZ3MqUWAxUWkh7NGZvhe0sGy9iOdANzwKw7mUUFViaCMR/t54W1
GC83sOs3D7n5Mj8x3NdO8xFit7dT9a245TvaoYQ7KgmqpSg/ScKCw4c3eiLava+J
3btnJeSIU+8ZXq9XjPRpKwUCgYA7z6LiOQKxNeXH3qHXcnHok855maUj5fJNpPbY
iDkyZ8ySF8GlcFsky8Yw6fWCqfG3zDrohJ5l9JmEsBh7SadkwsZhvecQcS9t4vby
9/8X4jS0P8ibfcKS4nBP+dT81kkkg5Z5MohXBORA7VWx+ACohcDEkprsQ+w32xeD
qT1EvQKBgQDKm8ws2ByvSUVs9GjTilCajFqLJ0eVYzRPaY6f++Gv/UVfAPV4c+S0
kAWpXbv5tbkkzbS0eaLPTKgLzavXtQoTtKwrjpolHKIHUz6Wu+n4abfAIRFubOdN
/+aLoRQ0yBDRbdXMsZN/jvY44eM+xRLdRVyMmdPtP8belRi2E2aEzA==
-----END RSA PRIVATE KEY-----
bandit13@bandit:~$ exit
```

•**cat sshkey.private**: Sunucudaki anahtarın içeriğini okuyup kopyalayarak kendi Windows bilgisayarımızda bir anahtar.txt dosyası oluşturduk.

•**ssh -i a.txt bandit14@... -p 2220**: Dışarıdan sunucuya bağlanırken -i (identity/kimlik) parametresini kullandık. Sisteme, *"Bana parola sorma, yetkimi kanıtlamak için elimdeki bu dosyayı kullan"* diyerek asimetrik şifrelemeyle güvenli giriş yaptık.

```
C:\Users\LENOVO>ssh -i sshkey.private bandit14@bandit.labs.overthewire.org -p 2220
Warning: Identity file sshkey.private not accessible: No such file or directory.
                         _                     _ _ _
                        | |__   __ _ _ __   __| (_) |_
                        | '_ \ / _` | '_ \ / _` | | __|
                        | |_) | (_| | | | | (_| | | |_
                        |_.__/ \__,_|_| |_|\__,_|_|\__|


                       This is an OverTheWire game server.
            More information on http://www.overthewire.org/wargames

backend: gibson-1
bandit14@bandit.labs.overthewire.org's password:

C:\Users\LENOVO>ssh -i a.txt bandit14@bandit.labs.overthewire.org -p 2220
                         _                     _ _ _
                        | |__   __ _ _ __   __| (_) |_
                        | '_ \ / _` | '_ \ / _` | | __|
                        | |_) | (_| | | | | (_| | | |_
                        |_.__/ \__,_|_| |_|\__,_|_|\__|


                       This is an OverTheWire game server.
            More information on http://www.overthewire.org/wargames

backend: gibson-1
```

```
bandit14@bandit:~$ cat /etc/bandit_pass/bandit14
MU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS
bandit14@bandit:~$ nc localhost 30000
^GMU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS
Wrong! Please enter the correct current password.
MU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS
bandit14@bandit:~$ cat /etc/bandit_pass/bandit14 | nc localhost 30000
Correct!
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo

bandit14@bandit:~$ exit
logout
Connection to bandit.labs.overthewire.org closed.
```

•**cat /etc/bandit_pass/bandit14 | nc localhost 30000**: Parolayı kopyala-yapıştır yaparken görünmez boşlukların da kopyalanması (insan hatası) riskini yok etmek için bu birleşik komutu kullandık. cat ile parola dosyasını okuduk, | (pipe) ile tuttuğumuz veriyi siber güvenliğin isviçre çakısı olan nc (Netcat) aracına verdik. Netcat de bu temiz veriyi doğrudan hedeflenen açık porta fırlattı.

```
C:\Users\LENOVO>ssh bandit15@bandit.labs.overthewire.org -p 2220
                      _                     _ _ _
                     | |__   __ _ _ __   __| (_) |_
                     | '_ \ / _` | '_ \ / _` | | __|
                     | |_) | (_| | | | | (_| | | |_
                     |_.__/ \__,_|_| |_|\__,_|_|\__|


                    This is an OverTheWire game server.
            More information on http://www.overthewire.org/wargames

backend: gibson-1
bandit15@bandit.labs.overthewire.org's password:

      ,----..            ,----,          .---.
     /   /   \        ,/   .`|         /. ./|
    /   .     :      ,`   .'  :    .--'.  ' ;
   .   /   ;.  \   ;    ;     /   /__./ \ : |
  .   ;   /  ` ;  .`---,/    ,` .--'.  '   \ ' .
  ;   |  ; \ ; | |   :     | /___/ \ |    ' '
  |   :  | ; | ' ;   |.';  ; ;   \  \;      :
  .   |  ' ' ' : `----'  |  | \   ;  `      |
  '   ;  \; /  |     '   :  ;  .   \   .\  ;
   \   \  ',  /      |   |  '   \   \   ' \ |
    ;   :    /       '   : |    :   '  |--"
     \   \ .'        ;   |.'      \   \ ;
  www. `---` ver     '---' he       '---"ire.org


Welcome to OverTheWire!
```

```
bandit15@bandit:~$ openssl s_client -connect localhost:30001
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN = SnakeOil
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN = SnakeOil
verify return:1
---
Certificate chain
 0 s:CN = SnakeOil
   i:CN = SnakeOil
   a:PKEY: rsaEncryption, 4096 (bit); sigalg: RSA-SHA256
   v:NotBefore: Jun 10 03:59:50 2024 GMT; NotAfter: Jun  8 03:59:50 2034 GMT
---
```


```
-----BEGIN CERTIFICATE-----
MIIFBzCCAu+gAwIBAgIUBLz7DBxA0IfojaL/WaJzE6Sbz7cwDQYJKoZIhvcNAQEL
BQAwEzERMA8GA1UEAwwIU25ha2VPaWwwHhcNMjQwNjEwMDM1OTUwWhcNMzQwNjA4
MDM1OTUwWjATMREwDwYDVQQDDAhTbmFrZU9pbDCCAiIwDQYJKoZIhvcNAQEBBQAD
ggIPADCCAgoCggIBANI+P5QXm9Bj21FIPsQqbqZRb5XmSZZJYaam7EIJ16Fxedf+
jXAv4d/FVqiEM4BuSNsNMeBMx2Gq0lAfN33h+RMTjRoMb8yBsZsC063MLfXCk4p+
09gtGP7BS6Iy5XdmfY/fPHvA3JDESCdlDDmd6Lsbdwhv93Q8M6POVO9sv4HuS4t/
jEjr+NhE+Bjr/wDbyg7GL71BP1WPZpQnRE4OzoSrt5+bZVLvODWUFwinB0fLaGRk
GmI0r5EUOUd7HpYyoIQbiNlePGfPpHRKnmdXTTEZEoxeWWAaM1VhPGqfrB/Pnca+
vAJX7iBOb3kHinmfVOScsG/YAUR94wSELeY+UlEWJaELVUntrJ5HeRDiTChiVQ++
wnnjNbepaW6shopybUF3XXfhIb4NvwLWpvoKFXVtcVjlOujF0snVvpE+MRT0wacy
tHtjZs7Ao7GYxDz6H8AdBLKJW67uQon37a4MI260ADFMS+2vEAbNSFP+f6ii5mrB
18cY64ZaF6oU8bjGK7BArDx56bRc3WFyuBIGWAFHEuB948BcshXY7baf5jjzPmgz
mq1zdRthQB31MOM2ii6vuTkheAvKfFf+llH4M9SnES4NSF2hj9NnHga9V08wfhYc
x0W6qu+S8HUdVF+V23yTvUNgz4Q+UoGs4sHSDEsIBFqNvInnpUmtNgcR2L5PAgMB
AAGjUzBRMB0GA1UdDgQWBBTPo8kfze4P9EgxNuyk7+xDGFtAYzAfBgNVHSMEGDAW
gBTPo8kfze4P9EgxNuyk7+xDGFtAYzAPBgNVHRMBAf8EBTADAQH/MA0GCSqGSIb3
DQEBCwUAA4ICAQAKHomtmcGqyiLnhziLe97Mq2+Sul5QgYVwfx/KYOXxv2T8ZmcR
Ae9XFhZT4jsAOUDK1OXx9aZgDGJHJLNEVTe9zWv1ONFfNxEBxQgP7hhmDBWdtj6d
taqEW/Jp06X+08BtnYK9NZsvDg2YRcvOHConeMjwvEL7tQK0m+GVyQfLYg6jnrhx
egH+abucTKxabFcWSE+Vk0uJYMqcbXvB4WNKz9vj4V5Hn7/DN4xIjFko+nREw6Oa
/AUFjNnO/FPjap+d68H1LdzMH3PSs+yjGid+6Zx9FCnt9qZydW13Miqg3nDnODXw
+Z682mQFjVlGPCA5ZOQbyMKY4tNazG2n8qy2famQT3+jF8Lb6a4NGbnpeWnLMkIu
jWLWIkA9MlbdNXuajiPNVyYIK9gdoBzbfaKwoOfSsLxEql f8rio1GGcEV5Hlz5S2
txwI0xdW9MWeGWoiLbZSbRJH4TIBFFtoBG0LoEJi0C+UPwS8CDngJB4TyrZqEld3
rH87W+Et1t/Nepoc/Eoaux9PFp5VPXP+qwQGmhir/hv7OsgBhrkYuhkjxZ8+1uk7
tUWC/XM0mpLoxsq6vVl3AJaJe1ivdA9xLytsuG4iv02Juc593HXYR8yOpow0Eq2T
U5EyeuFg5RXYwAPi7ykw1PW7zAPL4MlonEVz+QXOSx6eyhimp1VZC11SCg==
-----END CERTIFICATE-----
subject=CN = SnakeOil
```

```
subject=CN = SnakeOil
issuer=CN = SnakeOil
---
No client certificate CA names sent
Peer signing digest: SHA256
Peer signature type: RSA-PSS
Server Temp Key: X25519, 253 bits
---
SSL handshake has read 2103 bytes and written 373 bytes
Verification error: self-signed certificate
---
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
Server public key is 4096 bit
Secure Renegotiation IS NOT supported
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 18 (self-signed certificate)
---
---
Post-Handshake New Session Ticket arrived:
SSL-Session:
    Protocol  : TLSv1.3
    Cipher    : TLS_AES_256_GCM_SHA384
    Session-ID: 645BEF5EE89BAD503F284942FC0D59FC1A4EC8CAC5445896D2529C1E4305A58B
    Session-ID-ctx:
    Resumption PSK: A57C6EB1E318AD0267CFDD98BF64B8CEAE6CD0D5EB0666696F2171D1B9C4FCF27B80FB7A6CC682815DDF4DF1CEBC4009
    PSK identity: None
    PSK identity hint: None
```

```
    SRP username: None
    TLS session ticket lifetime hint: 300 (seconds)
    TLS session ticket:
    0000 - 59 18 5f 35 33 8f 4a e0-a9 7c 7b 75 09 a3 92 1e   Y._53.J..|{u....
    0010 - ac d2 5e 64 b0 26 df c9-e7 b3 55 67 a6 bb 54 6b   ..^d.&....Ug..Tk
    0020 - 17 4a 65 83 57 f8 a1 bf-c3 9b b3 b9 8f f0 f6 0f   .Je.W...........
    0030 - d4 b9 ce 3b 6f b3 fa b5-dc 6b 4f 9a 9a 48 1d e2   ...;o....kO..H..
    0040 - c9 51 13 42 a7 8f 64 7a-73 6a 1b e0 ed 49 84 6d   .Q.B..dzsj...I.m
    0050 - 71 28 a6 7d 20 0e 4b 7d-92 5d fd 90 11 d1 df 72   q(.} .K}.].....r
    0060 - 5f 72 cc 11 be 15 f8 e0-33 2f 37 ff f0 89 8c fd   _r......3/7.....
    0070 - 7e e4 95 4f 97 d6 99 ef-97 9b 66 6f 9a 94 b3 46   ~..O......fo...F
    0080 - e5 01 6d 08 c1 13 a9 56-00 11 90 9a 74 06 b6 0a   ..m....V....t...
    0090 - 00 22 d9 2e 06 31 c9 24-e7 20 ab 04 89 2f 8f e6   ."...1.$. .../..
    00a0 - ca ca 6a 2b 9c bf 7c 37-0a 2f 97 32 9f f6 23 f7   ..j+..|7./.2..#.
    00b0 - ad fb 20 5e cb 62 02 e8-c3 da 47 2b 02 71 e7 7e   .. ^.b....G+.q.~
    00c0 - ee 8e a7 69 ef 8b 56 69-a9 92 0a 32 1f 6c c8 54   ...i..Vi...2.l.T
    00d0 - fd 54 4f bf cf 32 b8 3c-21 2d 4f e6 23 36 1b 28   .TO..2.<!-O.#6.(

    Start Time: 1772877573
    Timeout   : 7200 (sec)
    Verify return code: 18 (self-signed certificate)
    Extended master secret: no
    Max Early Data: 0
---
read R BLOCK
---
Post-Handshake New Session Ticket arrived:
SSL-Session:
    Protocol  : TLSv1.3
    Cipher    : TLS_AES_256_GCM_SHA384
```

```
 Protocol  : TLSv1.3
 Cipher    : TLS_AES_256_GCM_SHA384
 Session-ID: 00B96B69E85B178DF565602DEAFBCA92325E4492FFC44F0C22476AC864970DA8
 Session-ID-ctx:
 Resumption PSK: 3930912F4CE2A116B3FB7F768DE1BAB3884C6F0B805E8A0043593A6884783D2B274877A568988DA37BE037FCB10659DE
 PSK identity: None
 PSK identity hint: None
 SRP username: None
 TLS session ticket lifetime hint: 300 (seconds)
 TLS session ticket:
 0000 - 59 18 5f 35 33 8f 4a e0-a9 7c 7b 75 09 a3 92 1e   Y._53.J..|{u....
 0010 - ba d1 12 20 69 eb df 35-cf cb 8f 86 6c dd ae 2a   ... i..5....l..*
 0020 - f4 36 32 1a 88 bc 23 2a-f2 77 34 09 43 54 1e 7f   .62...#*.w4.CT..
 0030 - cf 77 ee b4 c9 c9 3d c5-ad 92 21 6a f3 ef 18 d5   .w....=...!j....
 0040 - 53 05 45 71 7b 55 02 a9-51 d5 35 00 aa 08 8c 87   S.Eq{U..Q.5.....
 0050 - ef 26 86 ec 8c a5 3b 83-1c a0 fb 3a ab 3c 0a b5   .&....;....:.<..
 0060 - ba a0 8f e7 df dd 14 2d-71 c8 13 b6 02 96 3b c1   .......-q.....;.
 0070 - a3 52 94 07 47 df 08 a7-8b 6a f2 c2 71 ed 40 f3   .R..G....j..q.@.
 0080 - c6 18 86 4d 81 e3 05 91-6d f1 76 75 d9 57 4a f1   ...M....m.vu.WJ.
 0090 - bc 0c 54 7b 3e 87 86 2f-f1 63 68 22 4d 8e ed ea   ..T{>../.ch"M...
 00a0 - 89 81 e8 47 9d d9 cc 98-63 8f d4 37 9e 79 f7 3f   ...G....c..7.y.?
 00b0 - 7e ad c5 d8 62 c8 5b 26-eb d5 50 c1 f7 cd e0 70   ~...b.[&..P....p
 00c0 - 09 32 14 8b da 3f 45 f4-fd 32 47 fa e9 97 dc 5a   .2...?E..2G....Z
 00d0 - 97 bd d4 de cf ab a3 9d-92 d5 17 59 70 3a 0e cd   ...........Yp:..

 Start Time: 1772877573
 Timeout   : 7200 (sec)
 Verify return code: 18 (self-signed certificate)
 Extended master secret: no
 Max Early Data: 0
```

```
read R BLOCK
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
Correct!
kSkvUpMQ7lBYyCM4GBPvCvT1BfWRy0Dx

closed
bandit15@bandit:~$ exit
logout
Connection to bandit.labs.overthewire.org closed.

C:\Users\LENOVO>
```

•**openssl s_client -connect localhost:30001**: OpenSSL aracını kullanarak sunucunun 30001 numaralı portuyla güvenli bir el sıkışma (SSL Handshake) gerçekleştirdik ve aramızda dışarıdan okunması imkansız kriptografik bir tünel açtık. Tünel açıldıktan sonra parolayı gönderip 16. seviyenin anahtarını güvenle teslim aldık.

**Cephe 2: Web Mantık Avcısı (Server-Side)**

LEVEL-1

Bağış yapmak! Yardım!?

Natas

Natas, sunucu tarafı web güvenliğinin temellerini öğretiyor.

Natas'ın her seviyesi, seviye numarası olan X'in bulunduğu **http://natasX.natas.labs.overthewire.org** adresinde yer alan kendi web sitesinden oluşmaktadır . **SSH girişi bulunmamaktadır** . Bir seviyeye erişmek için, o seviyenin kullanıcı adını (örneğin, 0. seviye için natas0) ve şifresini girmeniz gerekir.

Her seviye, bir sonraki seviyenin şifresine erişebilir. Sizin göreviniz, bir şekilde bu şifreyi elde edip bir üst seviyeye geçmektir. **Tüm şifreler ayrıca /etc/natas_webpass/ dizininde saklanır** . Örneğin, natas5'in şifresi /etc/natas_webpass/natas5 dosyasında saklanır ve yalnızca natas4 ve natas5 tarafından okunabilir.

Buradan başlayın:

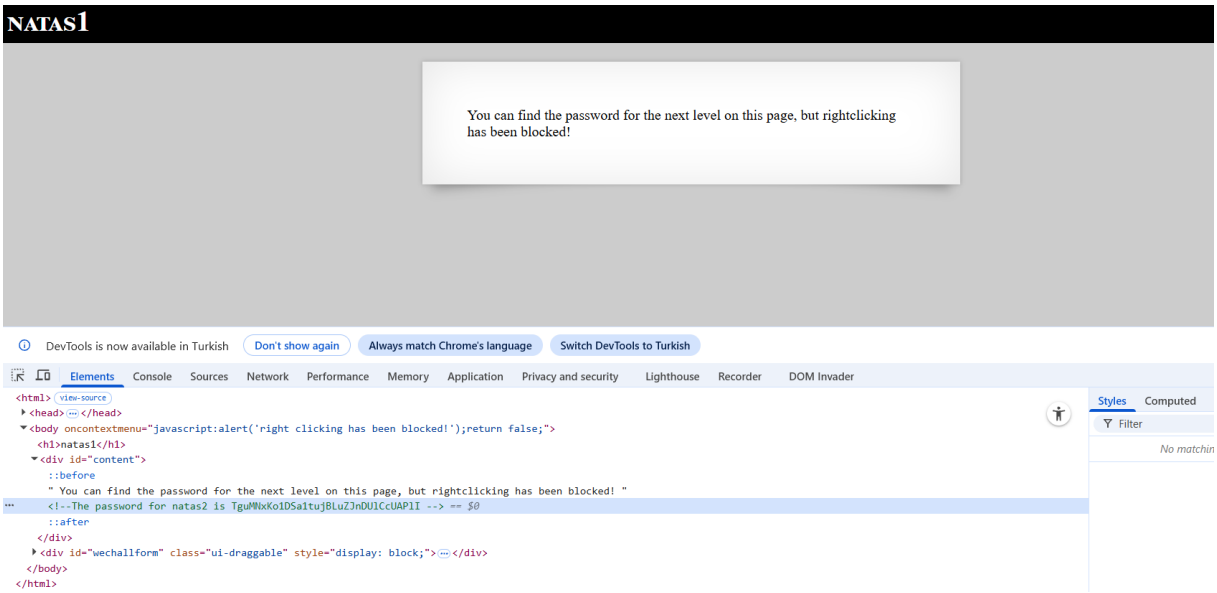
```
Username: natas0
Password: natas0
URL:      http://natas0.natas.labs.overthewire.org
```

Bu savaş oyununu çözmek için faydalı bulabileceğiniz araçlar

Bir web tarayıcısı, curl, ZAP proxy'si

Elements Console Sources Network » 1 1

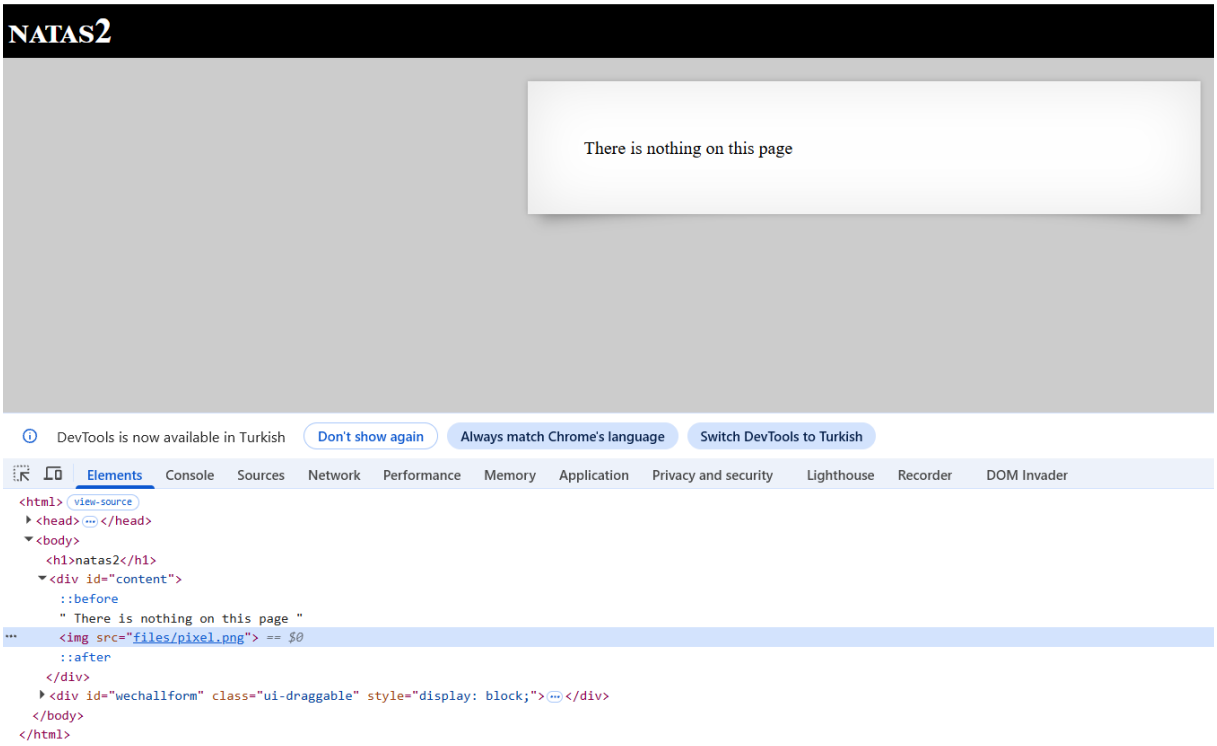
```
<html> view-source
  <head> ... </head>
  <body>
    <h1>natas0</h1>
    <div id="content">  == $0
      ::before
      " You can find the password for the next level on this page. "
      <!--The password for natas1 is 0nzCigAq7t2iALyvU9xcHlYN4MlkIwlq -->
      ::after
    </div>
    <div id="wechallform" class="ui-draggable" style="display: block;">
      <p>Submit token</p>
      <form id="realwechallform" action="https://www.wechall.net/10-levels-on-N
      atas.html" enctype="application/x-www-form-urlencoded" method="post">
        <input type="hidden" name="wfid" value="1">
        <input type="hidden" name="password_solution" value="natas0">
```




•**Zafiyetin Türü:** Information Disclosure (Bilgi İfşası) ve İstemci Tarafı Güvenlik Atlatma (Client-Side Security Bypass)

•**Kaynak Kod / Mantık Analizi:** Geliştirici, hassas veriyi (parolayı) yine HTML yorum satırları arasına gizlemiş. Ayrıca kaynak kodun incelenmesini zorlaştırmak amacıyla JavaScript ile sağ tıklama yasağı uygulamış. Ancak istemci tarafında alınan bu tür yüzeysel önlemler (Obscurity), tarayıcının yerleşik klavye kısayolları (Ctrl+U veya F12) kullanılarak kolayca atlatılabildiğinden bu durum büyük bir mantık zafiyetidir.

LEVEL-2



Güvenli değil natas2.natas.labs.overthewire.org/files/

# Index of /files

| Name | Last modified | Size | Description |
|---|---|---|---|
| Parent Directory | | - | |
| pixel.png | 2025-10-14 09:06 | 303 | |
| users.txt | 2025-10-14 09:06 | 145 | |

*Apache/2.4.58 (Ubuntu) Server at natas2.natas.labs.overthewire.org Port 80*

```
# username:password
alice:BYNdCesZqW
bob:jw2ueICLvT
charlie:G5vCxkVV3m
natas3:3gqisGdR0pjm6tpkDKdIWO2hSvchLeYH
eve:zo4mJWyNj2
mallory:9urtcpzBmH
```

•**Zafiyetin Türü:** Directory Listing (Açık Dizin Zafiyeti) / Information Disclosure

•**Kaynak Kod / Mantık Analizi:** Sayfa kaynağı incelendiğinde, ekrandaki 1x1 piksellik resmin sunucudaki files/ dizininden çekildiği tespit edilmiştir. URL üzerinden doğrudan files/ dizinine gidildiğinde, sunucunun klasör içeriğini listelemeye (Directory Indexing) açık bırakıldığı görülmüştür. Bu yapılandırma hatası sayesinde, dışarıdan erişime kapalı olması gereken users.txt dosyasına ulaşılarak hassas veri (parola) sızdırılmıştır.

LEVEL-3

Güvenli değil natas3.natas.labs.overthewire.org/robots.txt

```
User-agent: *
Disallow: /s3cr3t/
```

Güvenli değil natas3.natas.labs.overthewire.org/s3cr3t/

# Index of /s3cr3t

| Name | Last modified | Size | Description |
|---|---|---|---|
| Parent Directory | | - | |
| users.txt | 2025-10-14 09:06 | 40 | |

*Apache/2.4.58 (Ubuntu) Server at natas3.natas.labs.overthewire.org Port 80*

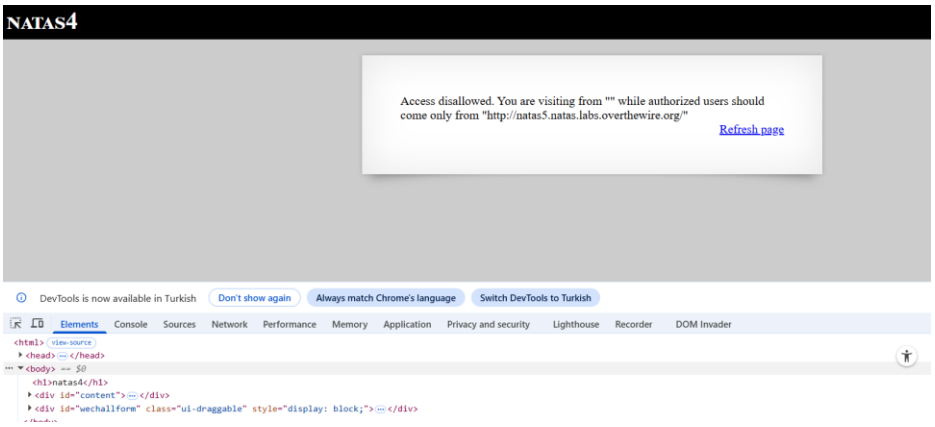
Güvenli değil natas3.natas.labs.overthewire.org/s3cr3t/users.txt

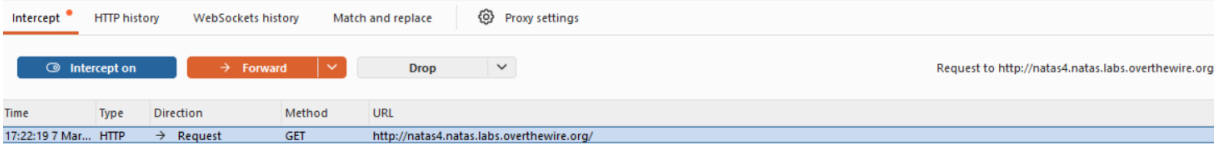
```
natas4:QryZXc2e0zahULdHrtHxzyYkj59kUxLQ
```

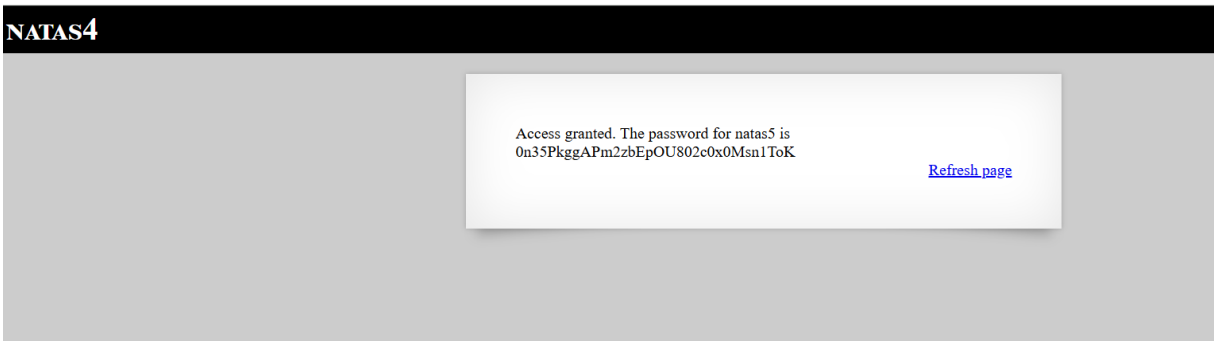
•**Zafiyetin Türü:** Information Disclosure (robots.txt İfşası) ve Directory Listing

•**Kaynak Kod / Mantık Analizi:** Sayfadaki "Google bile bulamayacak" ipucundan yola çıkılarak sunucunun kök dizinindeki robots.txt dosyası incelenmiştir. Geliştirici, arama motoru botlarını engellemek için yazdığı Disallow: /s3cr3t/ kuralı ile aslında dışarıdan bilinmemesi gereken gizli bir dizinin adını (s3cr3t) ifşa etmiştir. Bu dizine doğrudan gidildiğinde "Klasör Listeleme" zafiyeti sayesinde users.txt dosyasına ulaşılarak parola elde edilmiştir. Güvenlik, sadece bağlantıları gizleyerek (security through obscurity) sağlanamaz.

LEVEL-4





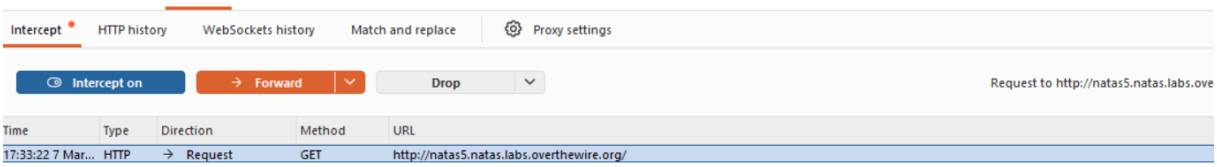

•**Zafiyetin Türü:** HTTP Referer Manipulation (Başlık Manipülasyonu) / Broken Access Control

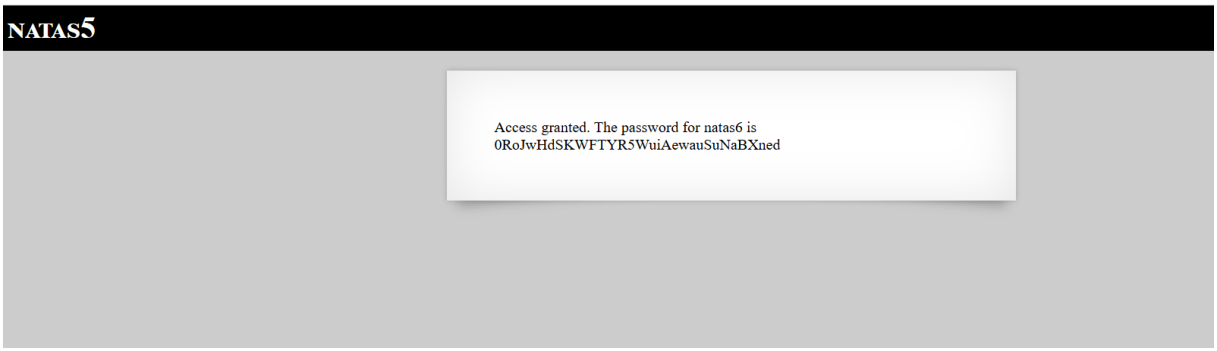
•**Kaynak Kod / Mantık Analizi:** Sayfa, kullanıcıların erişim yetkisini kontrol etmek için HTTP isteklerindeki Referer başlığına (header) güvenmektedir. Güvenlik mekanizmasının,

kullanıcının kolayca değiştirebileceği istemci tarafı (client-side) bir girdiye dayandırılması büyük bir mantık hatasıdır.

•**Sömürü (Exploitation) Adımı:** Burp Suite kullanılarak giden HTTP isteği Proxy üzerinden (Intercept) yakalanmıştır. İsteğin başlıkları arasına manuel olarak Referer: http://natas5.natas.labs.overthewire.org/ değeri eklenmiş ve istek sunucuya iletilmiştir. Sunucu bu sahte başlığı doğrulayarak kimlik doğrulamasını atlamış ve parolayı ekrana yansıtmıştır.

LEVEL-5



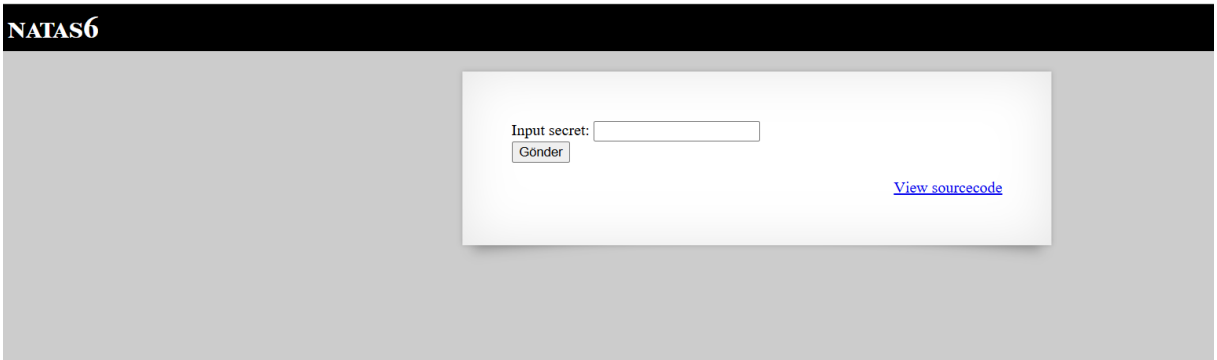



•**Zafiyetin Türü:** Broken Access Control / Insecure Cookie Management (Güvensiz Çerez Yönetimi)

•**Kaynak Kod / Mantık Analizi:** Uygulama, kullanıcının oturum durumunu ve yetkisini kontrol etmek için istemci tarafında saklanan showpassword isimli bir HTTP çerezine (cookie) güvenmektedir. Bu çerezin değeri 0 olduğunda erişim reddedilmekte, 1 olduğunda ise yetki verilmektedir.

•**Sömürü (Exploitation) Adımı:** Burp Suite ile yakalanan istekte, çerez değeri manuel olarak showpassword=1 şeklinde değiştirilmiştir. Sunucu tarafında ek bir doğrulama (session validation) yapılmadığı için kimlik doğrulama atlatılmış (Authentication Bypass) ve parola elde edilmiştir.

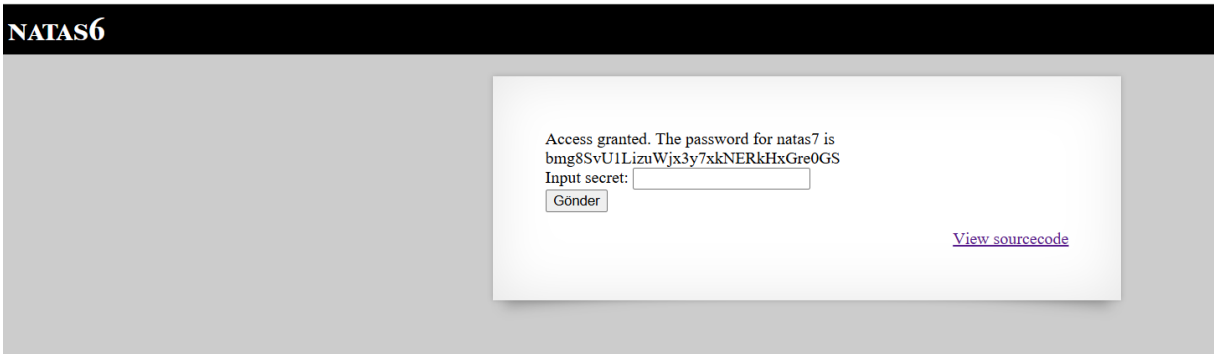
LEVEL-6




```
<script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
<script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
<script src=http://natas.labs.overthewire.org/js/wechall-data.js></script><script src="http:
<script>var wechallinfo = { "level": "natas6", "pass": "<censored>" };</script></head>
<body>
<h1>natas6</h1>
<div id="content">

<?

include "includes/secret.inc";

    if(array_key_exists("submit", $_POST)) {
        if($secret == $_POST['secret']) {
        print "Access granted. The password for natas7 is <censored>";
    } else {
        print "Wrong secret";
    }
    }
?>

<form method=post>
Input secret: <input name=secret><br>
<input type=submit name=submit>
```

Güvenli değil natas6.natas.labs.overthewire.org/includes/secret.inc

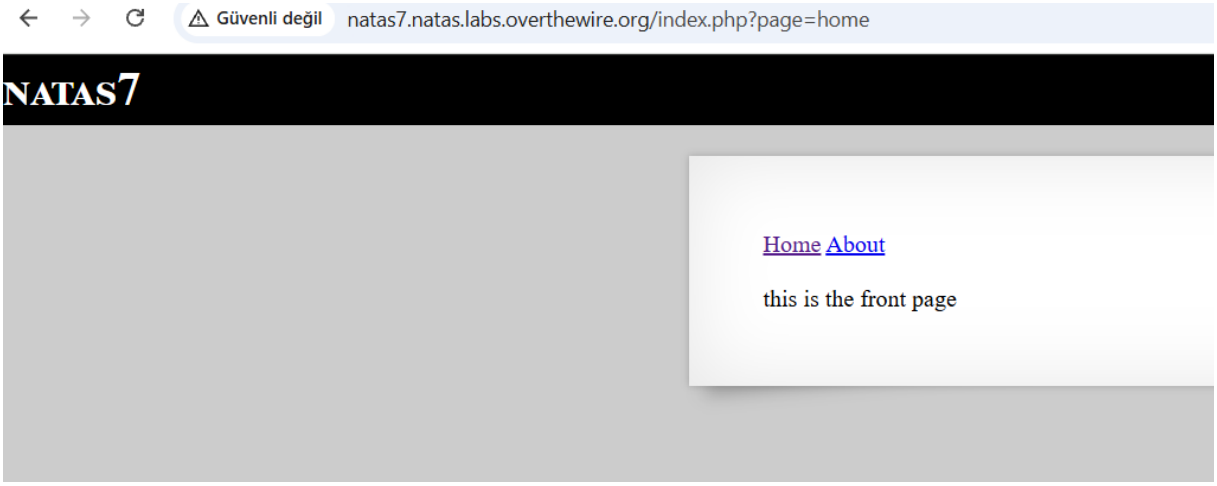
```
<?
$secret = "FOEIUWGHFEEUHOFUOIU";
?>
```

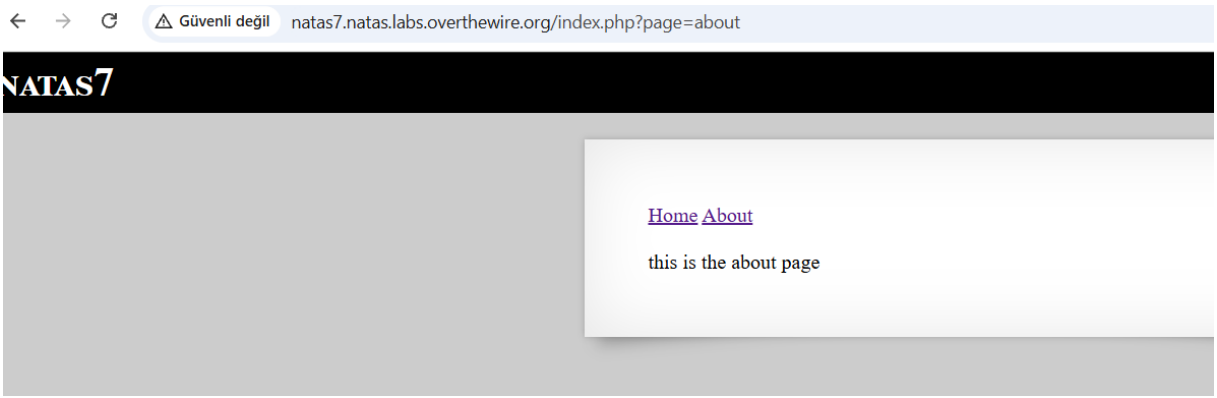


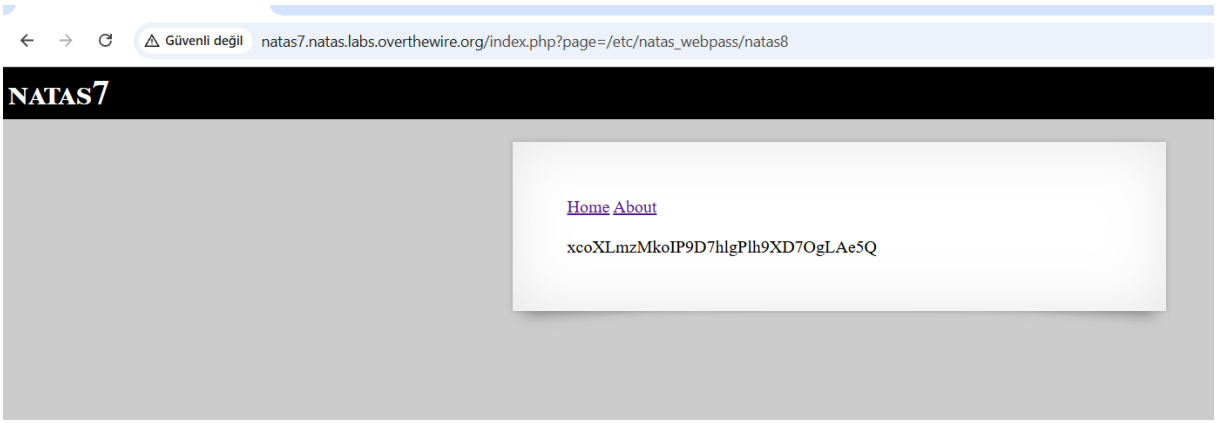

•**Zafiyetin Türü:** Sensitive Data Exposure (Hassas Veri İfşası) / Insecure File Storage
•**Kaynak Kod / Mantık Analizi:** PHP kaynak kodu incelendiğinde, doğrulama için kullanılan $secret değişkeninin dışarıdan bir dosya (includes/secret.inc) aracılığıyla dahil edildiği görülmüştür. Bu tür yapılandırma dosyalarının web sunucusunun erişilebilir dizinlerinde tutulması güvenlik ihlalidir.

•**Sömürü (Exploitation) Adımı:** URL üzerinden doğrudan includes/secret.inc dosyasına erişilmiş ve kaynak kodu görüntülenerek gizli "secret" değeri elde edilmiştir. Bu değer ana sayfadaki forma girilerek bir sonraki seviyenin parolasına ulaşılmıştır.

LEVEL-7



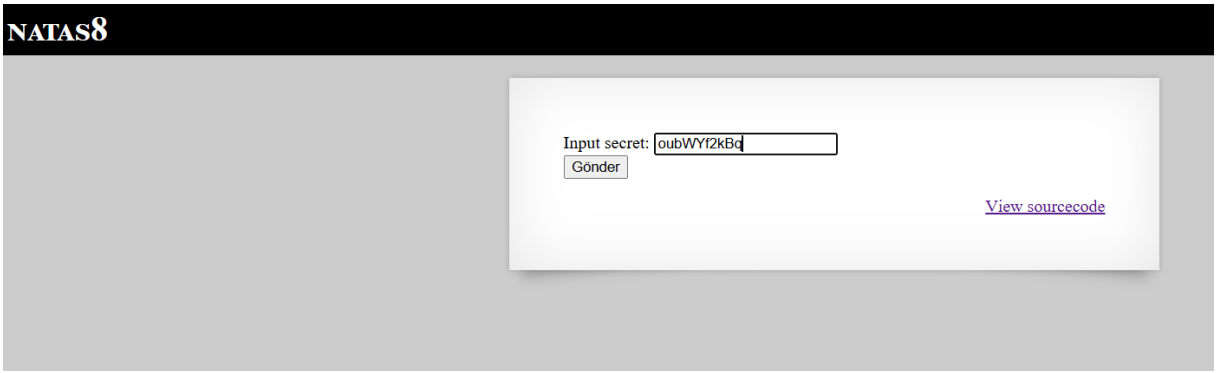

•**Zafiyetin Türü:** Local File Inclusion (LFI - Yerel Dosya Dahil Etme)

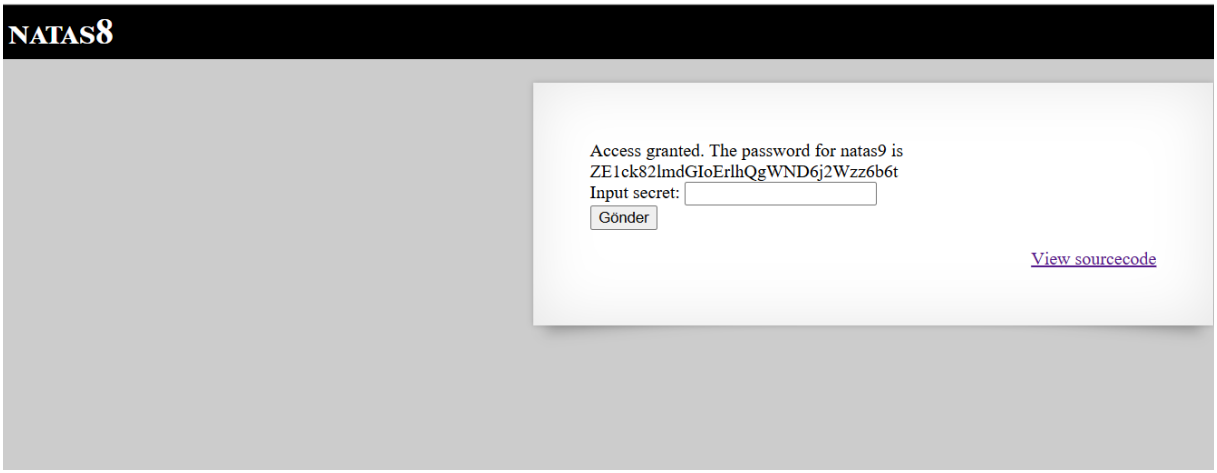
•**Kaynak Kod / Mantık Analizi:** Uygulama, page URL parametresi üzerinden gelen veriyi hiçbir temizleme (sanitization) veya beyaz liste (whitelist) kontrolünden geçirmeden doğrudan PHP include() fonksiyonuna iletmektedir. Bu durum, saldırganın sunucu üzerindeki rastgele dosyaları okumasına olanak tanır.

•**Sömürü (Exploitation) Adımı:** URL parametresi manipüle edilerek ?page=/etc/natas_webpass/natas8 dizini çağırılmıştır. Sunucu, kendi sistem dosyaları arasında yer alan bu hassas dosyayı okuyarak içeriğini web sayfasına yansıtmış ve bir sonraki seviyenin parolası elde edilmiştir.

LEVEL-8

```
<html>
<head>
<!-- This stuff in the header has nothing to do with the level -->
<link rel="stylesheet" type="text/css" href="http://natas.labs.overthewire.org/css/level.css">
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/jquery-ui.css" />
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/wechall.css" />
<script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
<script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
<script src=http://natas.labs.overthewire.org/js/wechall-data.js></script><script src="http://natas.labs.overthewire.org/js/wechall.js"></script>
<script>var wechallinfo = { "level": "natas8", "pass": "<censored>" };</script></head>
<body>
<h1>natas8</h1>
<div id="content">

<?

$encodedSecret = "3d3d516343746d4d6d6c315669563362";

function encodeSecret($secret) {
    return bin2hex(strrev(base64_encode($secret)));
}

if(array_key_exists("submit", $_POST)) {
    if(encodeSecret($_POST['secret']) == $encodedSecret) {
    print "Access granted. The password for natas9 is <censored>";
    } else {
    print "Wrong secret";
    }
}
?>

<form method=post>
Input secret: <input name=secret><br>
<input type=submit name=submit>
</form>

<div id="viewsource">a href="index-source.html">View sourcecode</a></div>
</div>
</body>
</html>
```



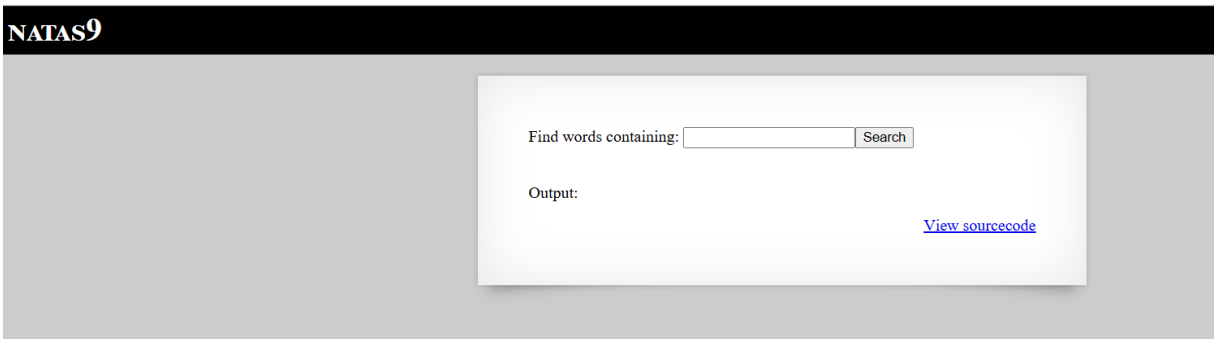

•**Zafiyetin Türü:** Insecure Cryptography / Weak Encoding (Zayıf Kodlama Mantığı)

•**Kaynak Kod / Mantık Analizi:** Uygulama, gizli bir değeri (secret) doğrulamak için geri döndürülebilir (reversible) bir kodlama zinciri kullanmaktadır. Geliştirici; Base64, String Reverse ve Hex fonksiyonlarını üst üste binmiş bir güvenlik önlemi sanmıştır. Ancak bu

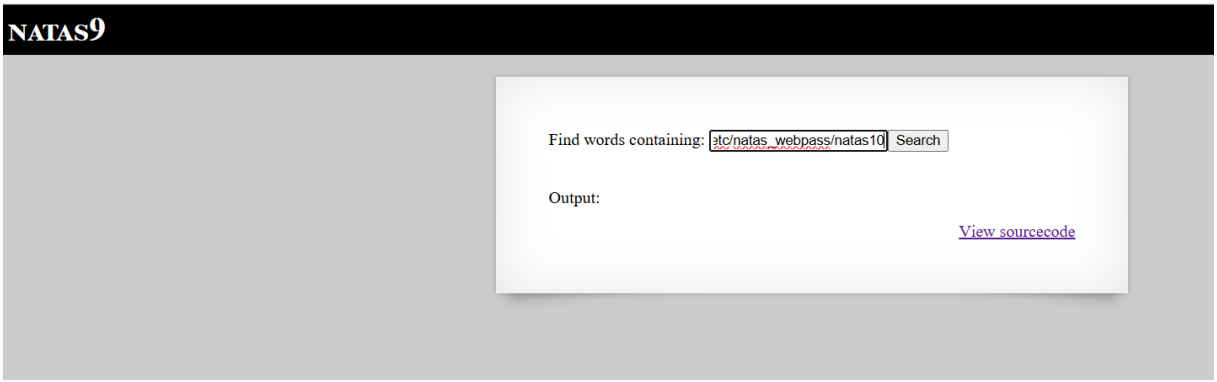
fonksiyonlar anahtar gerektirmediği için saldırgan tarafından tersine mühendislik (reverse engineering) ile kolayca çözülebilmektedir.

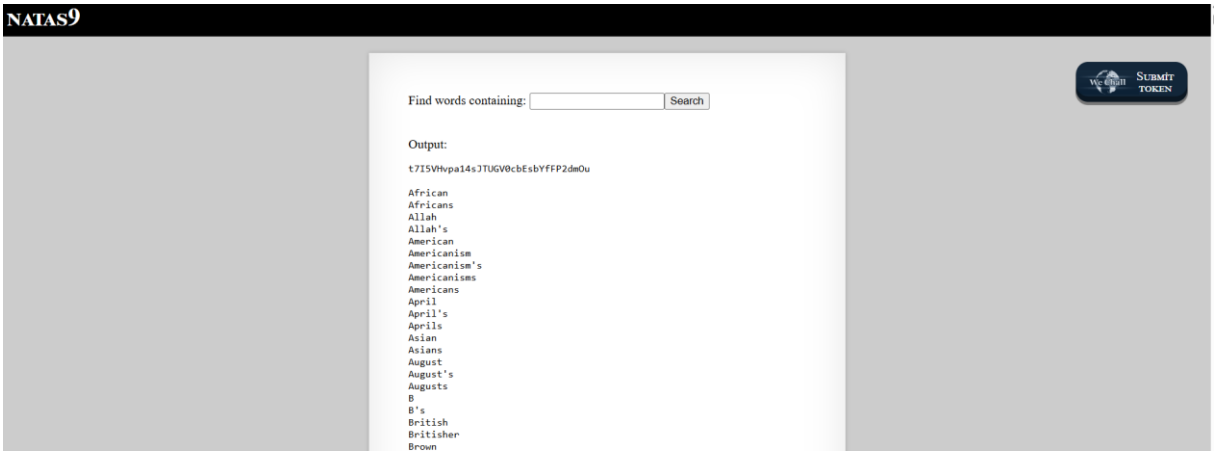
•**Sömürü (Exploitation) Adımı:** Kaynak koddaki encodeSecret fonksiyonu analiz edilmiş ve işlemler tam tersi sırada (Hex2Bin -> Reverse -> Base64Decode) uygulanarak orijinal secret değeri elde edilmiştir.

LEVEL-9




```
<html>
<head>
<!-- This stuff in the header has nothing to do with the level -->
<link rel="stylesheet" type="text/css" href="http://natas.labs.overthewire.org/css/level.css">
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/jquery-ui.css" />
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/wechall.css" />
<script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
<script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
<script src=http://natas.labs.overthewire.org/js/wechall-data.js></script><script src="http://natas.labs.overthewire.org/js/wechall.js"></script>
<script>var wechallinfo = { "level": "natas9", "pass": "<censored>" };</script></head>
<body>
<h1>natas9</h1>
<div id="content">
<form>
Find words containing: <input name=needle><input type=submit name=submit value=Search><br><br>
</form>


Output:
<pre>
<?
$key = "";

if(array_key_exists("needle", $_REQUEST)) {
    $key = $_REQUEST["needle"];
}

if($key != "") {
    passthru("grep -i $key dictionary.txt");
}
?>
</pre>

<div id="viewsource"><a href="index-source.html">View sourcecode</a></div>
</div>
</body>
</html>
```



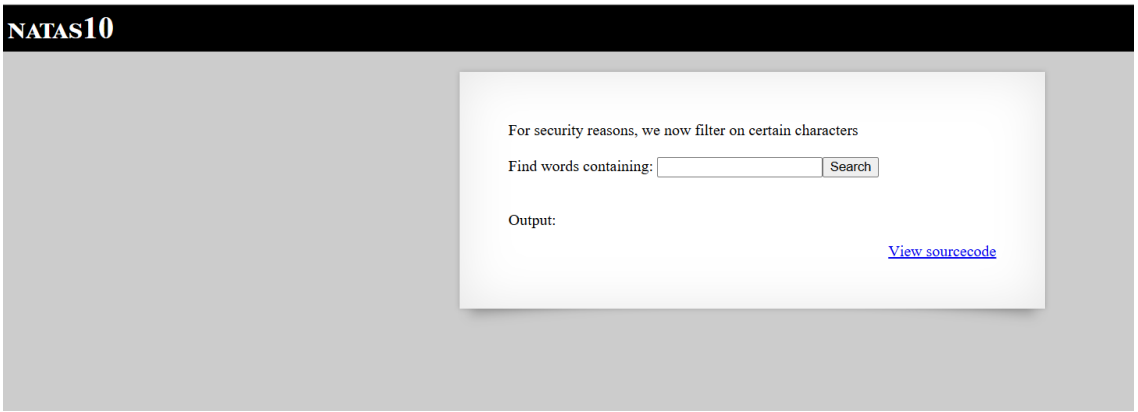




•**Zafiyetin Türü:** OS Command Injection (İşletim Sistemi Komut Enjeksiyonu)

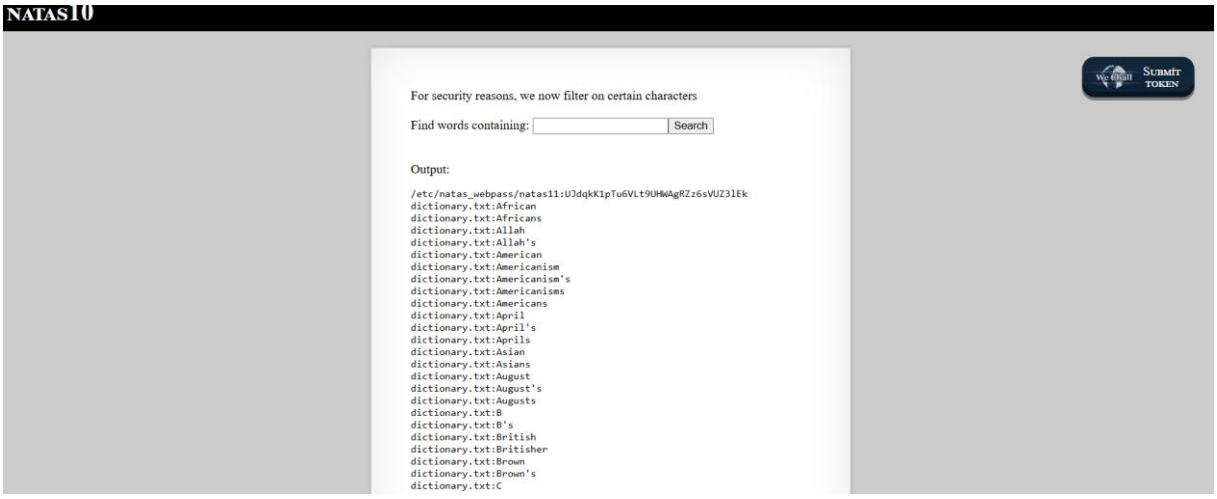
•**Kaynak Kod / Mantık Analizi:** PHP kaynak kodundaki passthru() fonksiyonu incelendiğinde, kullanıcıdan alınan girdinin ($key) hiçbir temizleme (sanitization) veya kaçış (escaping) işlemine tabi tutulmadan doğrudan sistem kabuğuna (shell) iletildiği tespit edilmiştir. Geliştirici sadece grep komutunun çalışacağını varsaymış ancak girdi alanını kısıtlamamıştır.

•**Sömürü (Exploitation) Adımı:** Arama kutusuna noktalı virgül (;) komut ayırıcısı kullanılarak ; cat /etc/natas_webpass/natas10 payload'ı enjekte edilmiştir. Bu sayede uygulamanın orijinal grep komutu sonlandırılmış ve peşinden gelen cat komutu sunucu tarafından yetkili bir şekilde çalıştırılarak bir sonraki seviyenin parolası ifşa edilmiştir.

LEVEL-10

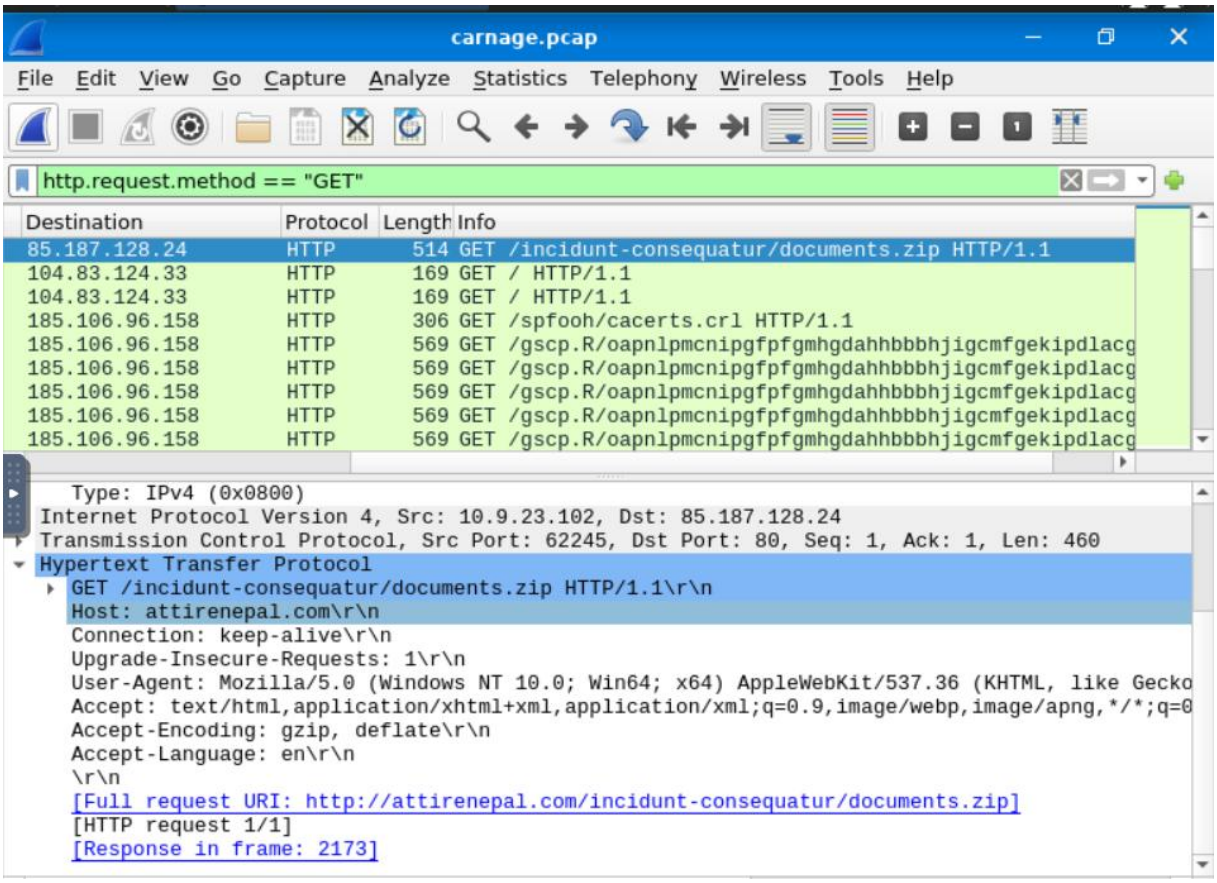


```
For security reasons, we now filter on certain characters<br/><br/>
<form>
Find words containing: <input name=needle><input type=submit name=submit value=Search><br><br>
</form>


Output:
<pre>
<?
$key = "";

if(array_key_exists("needle", $_REQUEST)) {
    $key = $_REQUEST["needle"];
}

if($key != "") {
    if(preg_match('/[;|&]/',$key)) {
        print "Input contains an illegal character!";
    } else {
        passthru("grep -i $key dictionary.txt");
    }
}
?>
</pre>

<div id="viewsource"><a href="index-source.html">View sourcecode</a></div>
</div>
</body>
</html>
```




•**Zafiyetin Türü:** OS Command Injection (Argument Injection / Blacklist Bypass) **Kaynak**
•**Kod / Mantık Analizi:** Geliştirici, bir önceki seviyedeki komut enjeksiyonunu önlemek için girdileri preg_match fonksiyonu ile bir kara listeye (;, |, &) sokmuştur. Ancak zafiyetin temel nedeni olan "kullanıcı girdisinin sistem komutuna doğrudan verilmesi" hatası düzeltilmemiştir. Sadece bazı karakterler yasaklanarak yüzeysel bir önlem alınmıştır.
•**Sömürü (Exploitation) Adımı:** Yeni bir komut başlatmak yerine, mevcut grep komutuna dışarıdan yeni bir "argüman" (dosya yolu) eklenmiştir. Arama alanına . /etc/natas_webpass/natas11 girdisi verilerek, uygulamanın asıl dosya olan dictionary.txt'nin yanı sıra sistemdeki parola dosyasının içindeki karakterleri de ekrana yazdırması (Argument Injection) sağlanmıştır.

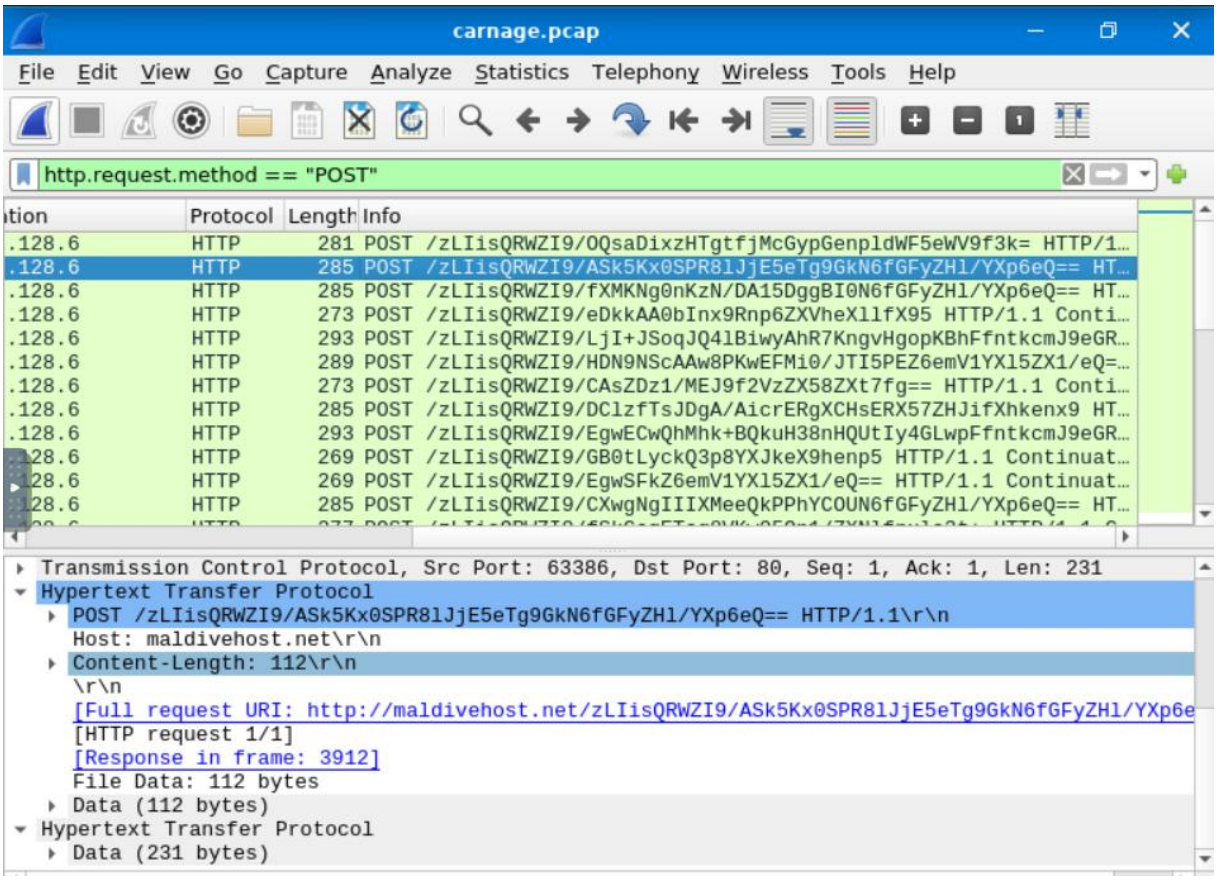
**Cephe 3: Kör Nokta Dedektifi (Ağ Adli Analizi):**




**Kullanılan Wireshark Filtresi: http.request.method == "GET"**

**Filtrenin Teknik Açıklaması:** > HTTP protokolünde GET metodu, bir istemcinin (bu senaryoda Eric'in bilgisayarının) sunucudan bir veri, web sayfası veya dosya "talep etmek" için kullandığı temel metottur. Oltalama (phishing) saldırılarında, zararlı makro çalıştıktan sonra asıl virüs dosyasını (payload) internetten bilgisayara indirmek için arka planda otomatik olarak bir HTTP GET isteği tetiklenir. Bu ağ trafiğinde (PCAP) dışarıdan içeriye doğru yapılan şüpheli dosya indirme işlemlerini izole edebilmek ve zararlı dosyanın adını bulabilmek amacıyla sadece GET isteklerini listeleyen bu filtre kullanılmıştır.

**Tespit:** Filtre sonucunda, attirenepal.com adresinden şüpheli bir documents.zip dosyasının indirildiği tespit edilmiştir.




**Kullanılan Wireshark Filtresi:** http.request.method == "POST"

**Filtrenin Teknik Açıklaması:**

HTTP protokolünde POST metodu, istemciden sunucuya veri "göndermek" (yüklemek) amacıyla kullanılır. Zararlı yazılımlar (Malware) enfekte oldukları sisteme yerleştikten sonra, topladıkları bilgileri dışarı sızdırmak (exfiltration) veya saldırgandan yeni emirler almak için Komuta Kontrol (C2) sunucularıyla haberleşirler. Buna siber güvenlikte "Beaconing" (Sinyal gönderme) denir. Virüsün dışarıya gönderdiği bu şifreli sinyalleri yakalayabilmek ve hacker'ın ana sunucusunun adresini bulabilmek için, ağdan dışarı çıkan veri paketlerini listeleyen HTTP POST filtresi uygulanmıştır.

**Tespit:** Filtre uygulandığında, maldivehost.net adresindeki C2 sunucusuna Base64 ile kodlanmış şüpheli parametreler içeren sürekli (beaconing) POST istekleri gönderildiği tespit edilmiştir.

# FAZ 2: Gerçek Saha Operasyonu (Web Recon & VDP Raporu)

## BÖLÜM C: Av Mevsimi (Saha Adımları)

### Cephe 1: Hedef Seçimi ve Keşif (Recon Haritası)

```
C:\Users\LENOVO\Downloads\subfinder_2.13.0_windows_amd64>subfinder.exe -d optus.com.au -all -o optus_subs.txt

                __    _____              __
   _______  __/ /_  / __(_)___  ____/ /__  _____
  / ___/ / / / __ \/ /_/ / __ \/ __  / _ \/ ___/
 (__  ) /_/ / /_/ / __/ / / / / /_/ /  __/ /
/____/\__,_/_.___/_/ /_/_/ /_/\__,_/\___/_/

                projectdiscovery.io

[INF] Current subfinder version v2.13.0 (latest)
[INF] Loading provider config from C:\Users\LENOVO\AppData\Roaming\subfinder\provider-config.yaml
[INF] Enumerating subdomains for optus.com.au
helpingsmallbusiness.optus.com.au
bt5620ap.optus.com.au
colesmobile.optus.com.au
ph.screens.retail.optus.com.au
ecmprs.optus.com.au
offtstappl002.optus.com.au
per.smb.optus.com.au
api.www-sit5.optus.com.au
monprdappla006.optus.com.au
tst5.toll.service-gateway.optus.com.au
agiprdappw500.optus.com.au
mm.vpdc.optus.com.au
sport-pp.optus.com.au
pextmc01.teams.optus.com.au
mx6.mms.optus.com.au
btu2kces.optus.com.au
```

```
C:\Users\LENOVO\Downloads\subfinder_2.13.0_windows_amd64>httpx.exe -l optus_subs.txt -mc 200 -o optus_alive.txt

    __    __  __       _  __
   / /_  / /_/ /_____ | |/ /
  / __ \/ __/ __/ __ \|   /
 / / / / /_/ /_/ /_/ /   |
/_/ /_/\__/\__/ .___/_/|_|
             /_/

                projectdiscovery.io

[INF] Current httpx version v1.9.0 (latest)
[WRN] UI Dashboard is disabled, Use -dashboard option to enable
https://apidev.optus.com.au
https://apidev-test.optus.com.au
https://beam.optus.com.au
https://brand.optus.com.au
https://corporateflex.optus.com.au
https://devicehelp.optus.com.au
https://go4.optus.com.au
https://go3.optus.com.au
https://images4.sport.optus.com.au
https://images1.sport.optus.com.au
https://images2.sport.optus.com.au
https://images5.sport.optus.com.au
https://iotflex.optus.com.au
https://link.paymentsupport.optus.com.au
https://link.paymentsupporttest.optus.com.au
http://images.sport.optus.com.au
```

```
https://apidev.optus.com.au
https://apidev-test.optus.com.au
https://beam.optus.com.au
https://brand.optus.com.au
https://corporateflex.optus.com.au
https://devicehelp.optus.com.au
https://go4.optus.com.au
https://go3.optus.com.au
https://images4.sport.optus.com.au
https://images1.sport.optus.com.au
https://images2.sport.optus.com.au
https://images5.sport.optus.com.au
https://iotflex.optus.com.au
https://link.paymentsupport.optus.com.au
https://link.paymentsupporttest.optus.com.au
http://images.sport.optus.com.au
http://images3.sport.optus.com.au
https://mi.optus.com.au
https://obapiv2.optus.com.au
https://obapi.optus.com.au
https://plnr.optus.com.au
https://ppt.obapiv2.optus.com.au
https://ppt.obapi.optus.com.au
https://sit.obapiv2.optus.com.au
https://sit.obapi.optus.com.au
https://status.sms.optus.com.au
https://sport.optus.com.au
https://stats.sport.optus.com.au
https://surveys.medallia.optus.com.au
https://trade-in.optus.com.au
http://static.sport.optus.com.au
https://wirelessip.optus.com.au
https://www.optus.com.au
https://www3.optus.com.au
https://www7.optus.com.au
https://yes4good.optus.com.au
```

```
C:\Users\LENOVO>dirsearch -u https://link.paymentsupport.optus.com.au -e php,txt,bak,zip,json,env -x 400,403,404,500
C:\Users\LENOVO\AppData\Local\Programs\Python\Python313\Lib\site-packages\requests\__init__.py:113: RequestsDependencyWa
rning: urllib3 (2.6.3) or chardet (7.0.1)/charset_normalizer (2.0.12) doesn't match a supported version!
  warnings.warn(

  _|. _ _  _  _  _ _|_    v0.4.3.post1
 (_||| _) (/_(_|| (_| )

Extensions: php, txt, bak, zip, json, env | HTTP method: GET | Threads: 25 | Wordlist size: 12021

Output File: C:\Users\LENOVO\reports\https_link.paymentsupport.optus.com.au\_26-03-11_13-56-18.txt

Target: https://link.paymentsupport.optus.com.au/

[13:56:18] Starting:
[14:01:48] 200 -    0B  - /soap/

Task Completed

C:\Users\LENOVO>
```

**Hedef:** Optus (Bugcrowd Platformu)

**Program Türü:** Public & Safe Harbor (Kapsam: *.optus.com.au)

**Recon (Bilgi Toplama) Aşamaları:**

1. subfinder kullanılarak hedef domainin tüm alt alan adları tespit edildi.
2. httpx kullanılarak bu listedeki aktif (HTTP 200) hedefler filtrelendi.
3. Filtrelenen şüpheli hedeflerden biri üzerinde (link.paymentsupport.optus.com.au) dirsearch ile gizli dizin taraması yapıldı.

**Tespit Edilen En Kritik 3 Bulgu:**

1. **Bulgu 1:** https://link.paymentsupport.optus.com.au
2. **Bulgu 2:** dirsearch -u https://link.paymentsupport.optus.com.au -e php,txt,bak,zip,json,env -x 400,403,404,500
3. **Bulgu 3:** httpx.exe -l optus_subs.txt -mc 200 -o optus_alive.txt
4. **Bulgu4:** subfinder.exe -d optus.com.au -all -o optus_subs.txt

## Cephe 2: Zafiyet Avı (Vulnerability Assessment)

**Request**

Pretty Raw Hex

```
4  Content-Length: 146
5  Cache-Control: max-age=0
6  Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
7  Sec-Ch-Ua-Mobile: ?0
8  Sec-Ch-Ua-Platform: "Windows"
9  Accept-Language: tr-TR,tr;q=0.9
10 Origin: https://oeauth.optus.com.au
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
   (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
14 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
   age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer:
   https://oeauth.optus.com.au/affwebservices/public/APIDevPortal.jsp?TYPE=100728
   833&REALMOID=06-000c91ce-3f91-190c-9160-51620a780000&GUID=&SMAUTHREASON=0&METH
   OD=GET&SMAGENTNAME=RNcWTRT00BCVVIgKUYQZm91ntJlik1UYxQtEq3Hsi92R62i6u31wherwYIq
   ydFrH&TARGET=-SM-HTTPS%3a%2f%2foeauth%2eoptus%2ecom%2eau%2faffwebservices%2fre
   directjsp%2fAPIDevPortalRedirect%2ejsp%3fSMPORTALURL%3dhttps-%3A-%2F-%2Foeauth
   %2eoptus%2ecom%2eau-%2Faffwebservices-%2Fpublic-%2Fsaml2sso%26SAMLTRANSACTIONI
   D%3d9973f701--9e77a355--e3b0b45c--0ae53736--0a611875--cc
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22 Connection: keep-alive
23
24 sysparm_ck=
   76276f1d300b40103ad7fc6530b3b5d906d1dd37e4f36a3a1516dc89fa16330b89823e5d&USER=
   test%40test.com&PASSWORD=&SMENC=ISO-8859-1&SMLOCALE=US-EN
```

Send Cancel Burp AI

**Request**

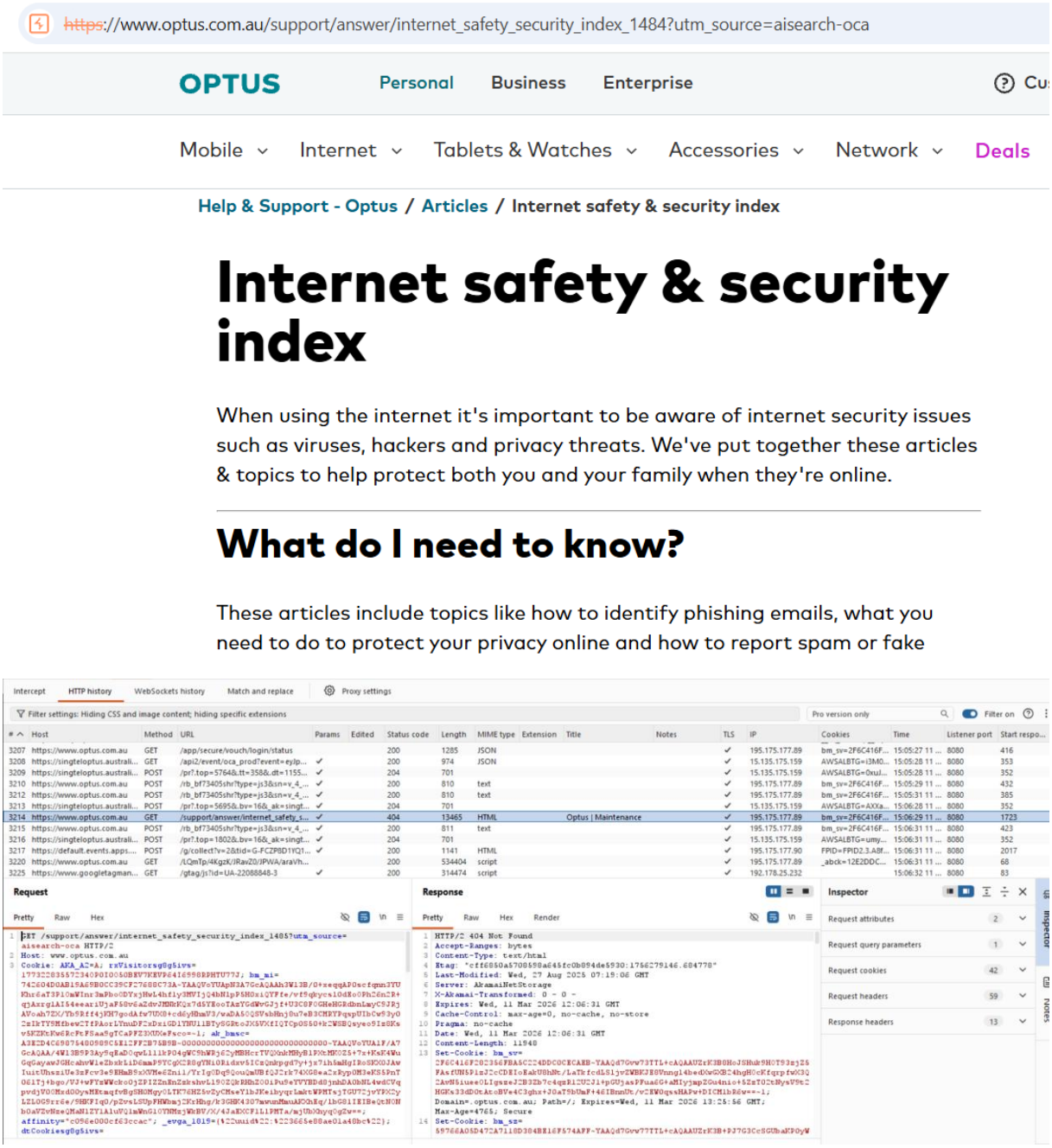
Pretty Raw Hex

```
4  Content-Length: 146
5  Cache-Control: max-age=0
6  Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
7  Sec-Ch-Ua-Mobile: ?0
8  Sec-Ch-Ua-Platform: "Windows"
9  Accept-Language: tr-TR,tr;q=0.9
10 Origin: https://oeauth.optus.com.au
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
   (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
14 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
   age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer:
   https://oeauth.optus.com.au/affwebservices/public/APIDevPortal.jsp?TYPE=100728
   833&REALMOID=06-000c91ce-3f91-190c-9160-51620a780000&GUID=&SMAUTHREASON=0&METH
   OD=GET&SMAGENTNAME=RNcWTRT00BCVVIgKUYQZm91ntJlik1UYxQtEq3Hsi92R62i6u31wherwYIq
   ydFrH&TARGET=-SM-HTTPS%3a%2f%2foeauth%2eoptus%2ecom%2eau%2faffwebservices%2fre
   directjsp%2fAPIDevPortalRedirect%2ejsp%3fSMPORTALURL%3dhttps-%3A-%2F-%2Foeauth
   %2eoptus%2ecom%2eau-%2Faffwebservices-%2Fpublic-%2Fsaml2sso%26SAMLTRANSACTIONI
   D%3d9973f701--9e77a355--e3b0b45c--0ae53736--0a611875--cc
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22 Connection: keep-alive
23
24 sysparm_ck=
   76276f1d300b40103ad7fc6530b3b5d906d1dd37e4f36a3a1516dc89fa16330b89823e5d&USER=
   ' OR 1=1 --&PASSWORD=&SMENC=ISO-8859-1&SMLOCALE=US-EN
```

Search 0 highlights Selection: 11 (0xb)

**Girdi Doğrulama ve Mantıksal Filtre Atlatma (SQLi/XSS Testi)**

•Uygulamanın apidev.optus.com.au adresindeki giriş (login) formunda girdi doğrulama testleri gerçekleştirilmiştir. İstemci tarafında (client-side) bulunan e-posta formatı filtresi, trafiğin Burp Suite (Repeater) üzerinden araya girilerek değiştirilmesiyle başarıyla atlatılmıştır (bypass). Bu sayede arka plana (backend) ' OR 1=1 -- test yükü (payload) gönderilerek sunucunun girdi işleme mantığı analiz edilmiştir.




### Erişim Kontrolü ve Manipülasyon (IDOR Testi)

•Uygulamanın nesne referanslarını nasıl yetkilendirdiğini test etmek amacıyla www.optus.com.au üzerindeki makale URL'sinde manipülasyon yapılmıştır. Adres çubuğunda tespit edilen makale ID değeri (1484), Burp Suite üzerinden manuel olarak 1485 ile değiştirilerek sunucuya iletilmiş ve HTTP 404 (Not Found) yanıtı dönmesi sağlanarak arka planın manipüle edilmiş ID'yi işleme aldığı doğrulanmıştır.

### Cephe 3: Profesyonel Raporlama (Kritik Teslimat)

### Güvenlik Değerlendirme Raporu (Security Assessment)

**Amaç ve Metodoloji:** Bu değerlendirmenin amacı, hedefin dışa açık saldırı yüzeyini haritalandırmak ve uygulama mantığındaki olası zafiyetleri manuel olarak test etmektir. Otomatize araçlarla (Subfinder, Httpx, Dirsearch) yapılan pasif ve aktif bilgi toplama (Recon) aşamasının ardından, Burp Suite Proxy ve Repeater kullanılarak istemci tarafı (client-side) güvenlik filtreleri atlatılmış ve doğrudan sunucu tarafı (backend) doğrulama mekanizmaları test edilmiştir.

**1. Test Edilen Endpointler (Hedefler):** Operasyon boyunca aşağıdaki kritik uç noktalar (endpoints) üzerinde güvenlik kontrolleri gerçekleştirilmiştir:

- **Gizli Dizin Taraması:** https://link.paymentsupport.optus.com.au/soap/ (API Haberleşme Noktası)
- **Girdi Doğrulama (Kimlik Doğrulama):** https://apidev.optus.com.au/ (Geliştirici Portalı Login Formu)
- **Erişim Kontrolü (Nesne Referansları):** https://www.optus.com.au/support/answer/internet_safety_security_index_1484 (Destek Makalesi URL'si)

**2. Kullanılan Payload'lar (Saldırı Vektörleri):** Sistemin filtreleme kapasitesini ölçmek için standart zararlı yükler kullanılmıştır:

- **SQL Injection (SQLi) Payload:** Login formundaki User Email alanına veri tabanı mantığını bozmak amacıyla ' OR 1=1 -- enjekte edilmiştir.
- **Insecure Direct Object Reference (IDOR) Payload:** URL parametreleri manipüle edilerek, yetkisiz erişim testi için ID değeri 1484 yerine 1485 olarak değiştirilmiştir.

**3. Bulgular ve Sistem Savunma Mekanizmaları:** Hedef sistem üzerinde yapılan testler sonucunda uygulamanın güvenlik duruşunun yüksek olduğu ve aşağıdaki savunma katmanlarının aktif olarak çalıştığı tespit edilmiştir:

- **İstemci Tarafı Doğrulama (Client-Side Validation):** E-posta giriş formunda @ işareti zorunluluğu gibi basit HTML5/Frontend filtreleri tespit edilmiştir
- **Sunucu Tarafı Veri Temizleme (Sanitization/ORM):** Burp Suite üzerinden zorla gönderilen ' OR 1=1 -- SQLi payload'u, backend tarafından güvenli bir şekilde işlenmiş (muhtemelen parametrik sorgular veya ORM araçları sayesinde zararsız bir metin olarak algılanmış) ve sistemde herhangi bir SQL hatasına veya kimlik doğrulama zafiyetine yol açmamıştır.
- **Erişim Kontrolü Savunması:** URL üzerindeki makale ID'si manuel olarak manipüle edildiğinde (1485), sunucu bu mantıksız talebi yakalamış ve "200 OK" ile başka bir veri sızdırmak yerine, güvenli bir şekilde **"404 Not Found"** hatası döndürmüştür.

## BÖLÜM D: Mühendislik Vizyonu (Reflection)

1. **Etki Analizi (Impact & CVSS Mantığı):**
   Sayın VDP Yetkilisi,
   Sisteminizde gerçekleştirdiğim güvenlik testleri sonucunda iki farklı XSS (Cross-Site Scripting) zafiyeti tespit ettim. Her ne kadar her iki bulgu da teknik olarak "XSS" başlığı altında değerlendirilse de, bulundukları bağlam (context), sömürülme senaryoları ve sisteminize verebilecekleri potansiyel zararlar (Impact) açısından aralarında uçurum vardır.
   Bu iki zafiyetin risk seviyelerini ve CVSS mantığını aşağıdaki gibi karşılaştırmalı olarak değerlendirebiliriz:
   1. Reflected XSS ("Hakkımızda" Sayfası Arama Çubuğu)

- Risk Seviyesi / CVSS: Orta (Medium) - Genellikle 5.4 ile 6.1 arası bir CVSS skoruna sahip olur.
- Sömürü Senaryosu: Saldırganın hazırladığı zararlı payload, sunucuya gider ve anında hedef kullanıcının tarayıcısına yansır (reflect).
- Neden Etkisi Daha Düşük?
  - Kullanıcı Etkileşimi (User Interaction - UI) Zorunludur: Kodun çalışması için saldırganın özel olarak hazırlanmış uzun ve şüpheli bir linki (URL) kurbana göndermesi ve kurbanı bu linke tıklamaya ikna etmesi gerekir (Sosyal Mühendislik).
  - Hedefin Belirsizliği: "Hakkımızda" gibi trafiği düşük ve kritik işlemlerin yapılmadığı bir sayfada, kurbanın yüksek yetkili bir kullanıcı (örneğin bir sistem yöneticisi) olma ihtimali çok düşüktür. Çalınacak olan oturum bilgisi büyük ihtimalle sıradan veya yetkisiz bir ziyaretçiye ait olacaktır.

   2. Stored XSS (İç Ağ / Admin Paneli Yorumlar Bölümü)

- Risk Seviyesi / CVSS: Yüksek / Kritik (High / Critical) - Genellikle 8.0 ve üzeri bir CVSS skoruna sahip olur.
- Sömürü Senaryosu: Zararlı kod veritabanına kaydedilir (store). Sayfayı ziyaret eden herkesin tarayıcısında dışarıdan bir müdahale olmadan otomatik olarak çalışır.
- Neden Etkisi Çok Daha Yıkıcı?
  - Otomatik Tetiklenme: Saldırganın kurbana link göndermesine gerek yoktur. Zararlı kod sistemin kalbine (veritabanına) yerleşmiştir.
  - Hedefin Kritikliği: Bu alan doğrudan "Yöneticiler" tarafından kullanıldığı için, kodu çalıştıracak olan kurbanlar en yüksek yetkiye sahip kişilerdir.
  - Etki (Impact): Yönetici paneli açıp yorumları okuduğu an, saldırgan sessizce yöneticinin oturumunu (session cookie) ele geçirebilir. Bu durum

sistemde tam yetkiyle (Account Takeover) yeni yöneticiler eklenmesine, kritik verilerin silinmesine veya sistemin tamamen ele geçirilmesine yol açar. Gizlilik (Confidentiality) ve Bütünlük (Integrity) üzerindeki etkisi maksimumdur.

Özetle Karşılaştırma: Reflected XSS senaryosunda saldırgan oltayı denize atıp rastgele birinin oltalama linkine tıklamasını beklerken; Stored XSS senaryosunda saldırgan mayını doğrudan komuta merkezine (Admin Paneline) döşemiştir. Yöneticinin paneli kullanması gibi rutin bir işlem, şirketin tüm kontrolünün kaybedilmesiyle sonuçlanabilir. Bu nedenle ikinci bulgunun derhal ve en yüksek öncelikle kapatılması gerekmektedir.

2. **Çözüm Üretmek (Mitigation):**
   **Neden Blacklisting (Karakter Yasaklama) İşe Yaramaz?**

- **Farklı Kodlama (Encoding) Yöntemleri ile Atlatma (Bypass):** Saldırganlar engellediğiniz karakterleri URL encoding (örneğin %27), Hex veya Unicode formatlarında göndererek güvenlik filtrenizi kolayca atlatabilirler. Filtreniz tırnak işaretini ararken, veritabanına ulaşan farklı formatlanmış girdi yine zararlı kod olarak çalışacaktır.
- **Tırnak Gerektirmeyen SQLi Türleri:** Eğer zafiyet olan alan bir metin (string) değil de bir tam sayı (integer) alanıysa (örneğin id=1), saldırganın komut çalıştırmak için tırnak işareti kullanmasına zaten gerek yoktur (Örn: id=1 OR 1=1).
- **Meşru Veriyi Bozma:** Tırnak işaretini yasaklamak, veritabanına kaydedilmesi gereken tamamen zararsız ve gerçek verilerin (örneğin "O'Connor" soyadı veya "Türkiye'nin" kelimesi) sisteme girilmesini de engeller ve iş mantığını bozar.

**Kök Çözüm: Parametrik Sorgular (Prepared Statements)**

SQL Injection zafiyetlerini donanımsal veya filtreleme mantığıyla değil, doğrudan yazılım mimarisiyle, **Parametrik Sorgular (Parameterized Queries)** veya bir ORM/ODM kullanarak çözmeliyiz.

**Bunun mantığı nedir ve neden kesin çözümdür?** Zafiyetin temel nedeni, kullanıcının girdiği verinin (Data) SQL motoru tarafından çalıştırılabilir bir komut (Code) olarak algılanmasıdır. Parametrik sorgular bu ikisini birbirinden tamamen ayırır (**Separation of Data and Code**).

1. **Sorgunun Hazırlanması:** Veritabanı motoruna önce sorgunun iskeleti gönderilir (Örn: SELECT * FROM users WHERE username = ?). Veritabanı bu komutu derler ve yapısını kilitler. Artık sorgunun mantığı değiştirilemez.
2. **Verinin Yerleştirilmesi:** Daha sonra kullanıcının girdiği girdi, bir parametre olarak bu iskelete gönderilir.
3. **Çalıştırma:** Kullanıcı girdi olarak admin' OR '1'='1 bile yazsa, veritabanı bunu bir SQL komutu olarak değil, **sadece düz bir metin değeri** olarak kabul eder. Veritabanında adı tam anlamıyla admin' OR '1'='1 olan bir kullanıcı arar ve bulamayıp güvenli bir şekilde boş döner.

Mevcut sistemin güvenliğini tam olarak sağlayabilmemiz için tüm veritabanı etkileşimlerimizde bu mimariye geçiş yapmamız kritik önem taşımaktadır